Aula 03 (Prof. Diego Carvalho e Renato da Costa)

Câmara dos Deputados - Informática e Dados

Autor:
Diego Carvalho, Renato da Costa, Equipe Informática e TI, Emannuelle Gouveia Rolim

07 de Agosto de 2026

02854629116 - Willian de Santana Angola

Índice

1) Segurança da Informação - Teoria 3

2) Segurança da Informação - Questões Comentadas - CEBRASPE 30

3) Segurança da Informação - Lista de Questões - CEBRASPE 41

02854629116 - Willian de Santana Angola

Tópicos da Aula

Tópicos da Aula 3
Segurança da Informação 6
Conceitos Básicos 6
Controles de Segurança 6
Princípios Fundamentais 7
Confidencialidade 7
Integridade 7
Disponibilidade 8
Princípios Adicionais 8
Autenticidade 8
Irretratabilidade 9
Criptologia 10
Conceitos Básicos 10
Esteganografia 10
Criptografia e Criptoanálise 10
Conceitos Básicos 10
Técnicas de Criptografia 11
Principais Algoritmos 13
Autenticidade 14
Conceitos Básicos 14
Método de Autenticação: O que você sabe? 14
Método de Autenticação: O que você é? 16
Método de Autenticação: O que você tem? 16
Autenticação Forte 17

02854629116 - Willian de Santana Angola

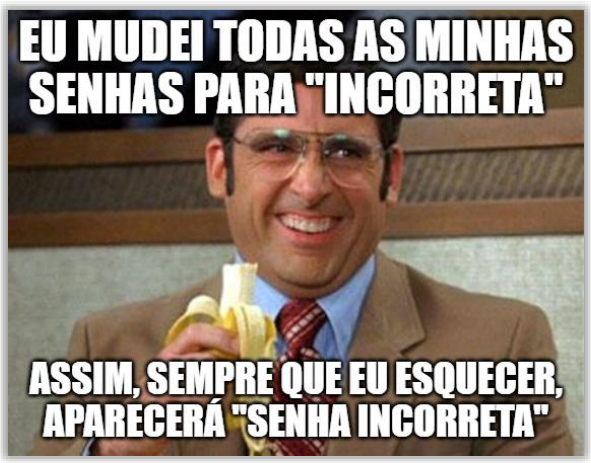
Assinatura Digital 18
Conceitos Básicos 18
Algoritmos de Hash 20
Controle de Acesso 21
Certificado Digital 23
Conceitos Básicos 23
Infraestrutura de Chave Pública (ICP-Brasil) 24
Tipos de Certificado 29

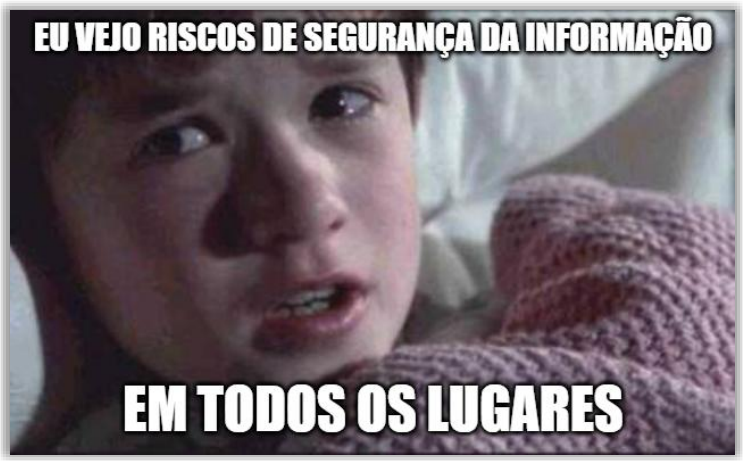
02854629116 - Willian de Santana Angola

APRESENTAÇÃO DA AULA

Pessoal, o tema da nossa aula é: **Segurança da Informação**. Nós vamos ver os conceitos básicos, terminologias e princípios fundamentais. Depois vamos entender mais sobre criptografia, assinatura digital e certificação digital. Esses são assuntos que estão no dia-a-dia de vocês mesmo que vocês não percebam. *Quem aí não viu as tretas que rolaram com hackeamento de celulares recentemente na política brasileira?* Pois é, ninguém está imune...

PROFESSOR DIEGO CARVALHO - WWW.INSTAGRAM.COM/PROFESSORDIEGOCARVALHO





Galera, todos os tópicos da aula possuem Faixas de Incidência, que indicam se o assunto cai muito ou pouco em prova. *Diego, se cai pouco para que colocar em aula?* Cair pouco não significa que não cairá justamente na sua prova! A ideia aqui é: se você está com pouco tempo e precisa ver somente aquilo que cai mais, você pode filtrar pelas incidências média, alta e altíssima; se você tem tempo sobrando e quer ver tudo, vejam também as incidências baixas e baixíssimas. *Fechado?*

INCIDÊNCIA EM PROVA: BAIXÍSSIMA
INCIDÊNCIA EM PROVA: BAIXA
INCIDÊNCIA EM PROVA: MÉDIA
INCIDÊNCIA EM PROVA: ALTA
INCIDÊNCIA EM PROVA: ALTÍSSIMA

Além disso, essas faixas não são por banca – é baseado tanto na quantidade de vezes que caiu em prova independentemente da banca e também em minhas avaliações sobre cada assunto...

02854629116 - Willian de Santana Angola

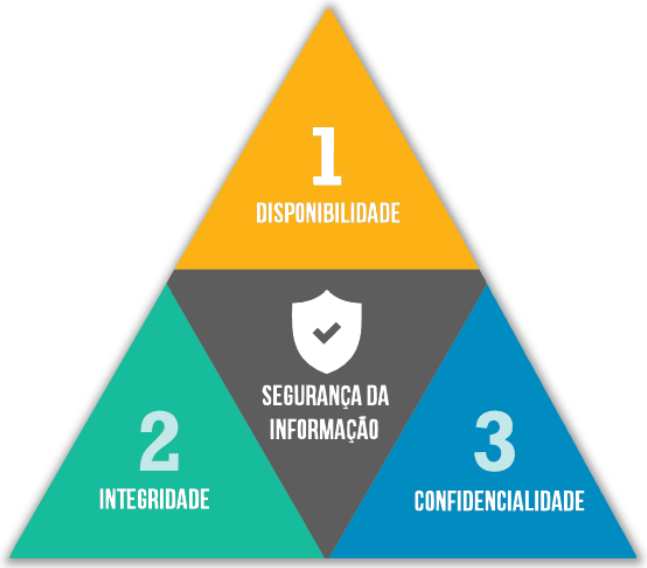
SEGURANÇA DA INFORMAÇÃO

Conceitos Básicos

INCIDÊNCIA EM PROVA: BAIXA

Muitas pessoas protegem seus bens físicos, mas negligenciam a segurança de suas informações. Em um mundo cada vez mais digital, isso é um erro. Informações valem dinheiro e precisam ser protegidas com a mesma seriedade. Mesmo em 2025, senhas fracas como "123456" ainda são comuns. Com o crescimento exponencial do volume de dados, aumentam também os riscos. Todas as pessoas e organizações, independentemente do porte, lidam com dados que exigem proteção. Nesse sentido, vejamos algumas definições de segurança da informação:

DEFINIÇÕES DE SEGURANÇA DA INFORMAÇÃO
Proteção de informações e de sistemas de informações contra acesso, uso, divulgação, interrupção, modificação ou destruição não autorizados.
Salvaguarda de dados organizacionais contra acesso não autorizado ou modificação para assegurar sua disponibilidade, confidencialidade e integridade.
Conjunto de estratégias para gerenciar processos, ferramentas e políticas necessárias para prevenir, detectar, documentar e combater ameaças às informações organizacionais.



Segurança da Informação é o conjunto de práticas que visa proteger informações contra acessos e usos não autorizados, garantindo: confidencialidade (somente pessoas autorizadas podem acessar a informação), Integridade (a informação permanece correta e completa) e Disponibilidade (a informação está acessível quando necessária). Esses três pilares formam a base da Segurança da Informação e, se violados, caracterizam um incidente.

Controles de Segurança

INCIDÊNCIA EM PROVA: BAIXA

Na segurança da informação, o primeiro passo é avaliar riscos e aplicar os controles certos para proteger os dados, reduzindo ameaças sem gastar com medidas desnecessárias. Controles de segurança são

02854629116 - Willian de Santana Angola

mecanismos usados para proteger a confidencialidade, integridade e disponibilidade das informações. Eles se dividem em dois tipos:

TIPO DE CONTROLE	DESCRIÇÃO
CONTROLES FÍSICOS	São barreiras que impedem ou limitam o acesso físico direto às informações ou à infraestrutura que contém as informações. Ex: portas, trancas, paredes, blindagem, vigilantes, geradores, sistemas de câmeras, alarmes, catracas, cadeados, salas-cofre, alarmes de incêndio, crachás de identificação, entre outros.
CONTROLES LÓGICOS	Também chamados de controles técnicos, são barreiras que impedem ou limitam o acesso à informação por meio do monitoramento e controle de acesso a informações e a sistemas de computação. Ex: senhas, firewalls, listas de controle de acesso, criptografia, biometria[1], IDS, IPS, entre outros.

Importante: o tipo de controle depende do recurso protegido, não do método usado. Ex: usar biometria para entrar numa sala = controle físico; usar para acessar um sistema = controle lógico.

Princípios Fundamentais

Confidencialidade

INCIDÊNCIA EM PROVA: ALTÍSSIMA

Confidencialidade é o princípio da segurança da informação que garante que apenas pessoas, sistemas ou processos autorizados possam acessar certos dados. É como manter a privacidade de uma informação. Exemplo: uma carta lacrada. Se alguém não autorizado rompe o lacre e lê, a confidencialidade foi violada. O mesmo vale para e-mails, senhas, arquivos, fotos, entre outros.

A confidencialidade deve ser preservada: na criação da informação; durante sua transmissão; no armazenamento; e até no descarte (com exclusão segura dos dados). Atenção: confidencialidade é diferente de confiabilidade, dado que a confiabilidade é a capacidade de um sistema funcionar corretamente e sem falhas.

Integridade

INCIDÊNCIA EM PROVA: ALTÍSSIMA

Integridade é o princípio que garante que a informação está correta, completa e não foi alterada sem autorização, desde sua origem até o destino. Ela assegura que os dados não foram modificados, excluídos ou corrompidos, acidental ou propositalmente; o conteúdo recebido é idêntico ao que foi enviado; e alterações só ocorrem de forma autorizada. Exemplo: se uma carta chega lacrada e sem alterações, a integridade foi mantida. Se ela for modificada no caminho, a integridade foi violada. Importante: integridade e confidencialidade são princípios distintos. É possível violar um sem comprometer o outro.

[1] A biometria é polêmica: há algumas classificações que a colocam como controle lógico e outras como físico ou lógico a depender do que ela se propõe a proteger.

02854629116 - Willian de Santana Angola

Disponibilidade

INCIDÊNCIA EM PROVA: ALTÍSSIMA

Disponibilidade é o princípio que garante que a informação esteja acessível e utilizável sempre que for necessária, por usuários autorizados. Ter dados salvos não é suficiente – é preciso que estejam acessíveis no momento certo. Exemplo: se você tenta usar o app do banco para uma transferência urgente e ele está fora do ar, a disponibilidade foi comprometida.

Em empresas, falhas de disponibilidade podem gerar grandes prejuízos. Por isso, investem em recursos como: backups atualizados; redundância de servidores; fontes de energia ininterrupta (no-breaks); firewalls e proteção contra-ataques; e monitoramento contínuo. Essas medidas garantem que os sistemas continuem funcionando mesmo em situações adversas.

Saiba mais:

Há uma pegadinha clássica que trata da diferença entre Confidencialidade e Disponibilidade. A Confidencialidade garante que a informação somente esteja acessível para usuários autorizados. Já a Disponibilidade garante que a informação esteja disponível aos usuários autorizados sempre que necessário (notem que existem dois requisitos).

Princípios Adicionais

A tríade da segurança da informação é formada por Confidencialidade, Integridade e Disponibilidade (CID) – os pilares mais fundamentais da proteção de dados. No entanto, alguns especialistas ampliam essa base, incluindo mais dois princípios:

- **Autenticidade:** garante que a informação foi criada, enviada ou recebida por quem realmente declara tê-lo feito.
- **Irretratabilidade (ou Não-Repúdio):** assegura que o autor de uma ação não possa negar que a realizou, essencial em assinaturas digitais e transações online.

Já Donn B. Parker propôs o Hexagrama Parkeriano, um modelo com seis atributos: Confidencialidade, Integridade, Disponibilidade, Autenticidade, Posse (Controle) e Utilidade. Vejamos:

- **Posse ou Controle:** quem realmente detém a informação, independentemente de quem a criou (ex: perda de celular com dados sigilosos).
- **Utilidade:** a informação deve estar em formato acessível e compreensível; não basta existir, deve ser útil.

Autenticidade

INCIDÊNCIA EM PROVA: ALTÍSSIMA

Autenticidade é o princípio que garante que uma informação foi enviada ou acessada por quem realmente diz ser. É a confirmação da identidade do autor ou solicitante. Exemplo comum: uma assinatura em contrato ou uma conta verificada em redes sociais. Esses métodos indicam que a identidade é

02854629116 - Willian de Santana Angola

legítima, embora possam ser burlados se não forem bem protegidos. Importante: mesmo sem segurança absoluta, consideramos que há autenticidade quando não houve falhas ou incidentes no processo de verificação. Temos dois tipos de autenticação:

- **Autenticação de Origem dos Dados:** pode ocorrer sem conexão e busca garantir que a origem dos dados recebidos é realmente de quem diz ser.

- **Autenticação de Entidade Par:** ocorre com conexão e busca garantir a confiabilidade da identidade das entidades conectadas.

Irretratabilidade

INCIDÊNCIA EM PROVA: ALTÍSSIMA

Irretratabilidade (ou Não-repúdio) é o princípio que garante que o autor de uma mensagem ou ação não possa negar sua autoria posteriormente. Muito usado em contratos e transações digitais, tem valor tanto técnico quanto jurídico. Embora tecnologias como assinaturas digitais e criptografia ajudem a garantir esse princípio, ele envolve também aspectos legais — por exemplo, a responsabilidade por publicações feitas em contas verificadas.

E qual é a diferença entre Autenticidade e Irretratabilidade? A Autenticidade confirma quem enviou a mensagem; já a Irretratabilidade impede que o remetente negue que foi o autor da mensagem recebida. Exemplo: uma carta com sua assinatura garante a autenticidade, mas – para garantir que o conteúdo não foi alterado no caminho – é necessário também garantir a integridade da mensagem. Quando ambas são asseguradas, temos a irretratabilidade.

02854629116 - Willian de Santana Angola

CRIPTOLOGIA

Conceitos Básicos

INCIDÊNCIA EM PROVA: BAIXÍSSIMA

A Criptologia é a área que trata da proteção de informações e da tentativa de quebrar esses mecanismos de proteção. Divide-se em:

- **Criptografia:** oculta a informação para impedir acessos não autorizados.
- **Criptoanálise:** busca quebrar ou decifrar informações protegidas.

A ocultação da informação pode ser feita por:

- **Esteganografia:** esconde a existência da informação (ex: mensagem oculta em uma imagem).
- **Criptografia**: transforma o conteúdo da informação para torná-la ilegível sem a chave correta.

Na criptografia, existem dois grupos principais:

- **Códigos:** usam palavras, frases ou símbolos para representar partes da mensagem original.
- **Cifras:** aplicam algoritmos para criptografar e descriptografar mensagens

As principais técnicas de criptografia são:

- **Substituição:** troca de caracteres por outros símbolos.
- **Transposição:** mudança da ordem dos caracteres no texto.

Esteganografia

INCIDÊNCIA EM PROVA: BAIXA

Esteganografia é a técnica de ocultar informações dentro de outras informações aparentemente inofensivas, de forma que a existência da mensagem passe despercebida. Diferente da criptografia, que embaralha o conteúdo da mensagem para torná-la ilegível, a esteganografia esconde o fato de que há uma mensagem ali. Em outras palavras, enquanto a criptografia protege o conteúdo, a esteganografia protege a existência da comunicação.

Criptografia e Criptoanálise

Conceitos Básicos

INCIDÊNCIA EM PROVA: BAIXA

Criptografia é uma técnica da segurança da informação que tem como objetivo proteger dados, transformando informações legíveis em códigos indecifráveis, de modo que somente pessoas autorizadas consigam acessá-las. Esse processo ocorre por meio de algoritmos matemáticos e chaves criptográficas, que embaralham os dados na origem (processo chamado de cifragem) e permitem que sejam decifrados corretamente apenas no destino (decifragem).

02854629116 - Willian de Santana Angola

Técnicas de Criptografia

Atualmente são empregadas técnicas de criptografias simétricas, assimétricas e híbridas. Essas técnicas empregam dois fundamentos principais: substituição, em que cada elemento no texto claro é mapeado para outro elemento; e transposição, em que os elementos no texto claro original são reorganizados. O requisito essencial de ambos é que nenhuma informação seja perdida!

Criptografia Simétrica[2]

INCIDÊNCIA EM PROVA: ALTÍSSIMA

Criptografia simétrica é um método de proteção de dados em que a mesma chave é usada tanto para criptografar quanto para descriptografar a informação, isto é, quem envia e quem recebe precisam ter acesso à mesma chave secreta. É uma técnica rápida e eficiente, muito utilizada para proteger grandes volumes de dados, mas exige cuidado na distribuição segura da chave, pois, se ela for interceptada, toda a comunicação pode ser comprometida.

Na criptografia simétrica, a mesma chave é usada para criptografar e descriptografar a informação. Exemplo: Maria quer enviar um documento protegido para João. Ela o criptografa com uma senha e envia o arquivo. Porém, João só poderá acessá-lo se tiver essa mesma senha. O problema está na troca da chave: se for enviada por e-mail ou outro canal inseguro, pode ser interceptada. Se for passada pessoalmente, pode ser inconveniente.

Pontos importantes: a chave precisa ser protegida com muito cuidado; a segurança do sistema depende diretamente da proteção dessa chave; e quanto mais pessoas usam a mesma chave, maior o risco de comprometimento. Já quanto às garantias fornecidas: Confidencialidade (garantida pela própria criptografia); Integridade (pode ser verificada comparando o texto original com o criptografado); Autenticidade (garantida se apenas as partes legítimas conhecem a chave); Não-repúdio (não é garantido, pois qualquer parte com a chave pode negar autoria da mensagem).

- **Principais algoritmos:** DES, 3DES, AES, IDEA, RC4, Blowfish, Cifragem de Júlio César, etc.

Criptografia Assimétrica

INCIDÊNCIA EM PROVA: ALTÍSSIMA

Criptografia assimétrica é um método de segurança que utiliza um par de chaves distintas, mas matematicamente relacionadas: uma chave pública (que pode ser compartilhada com qualquer pessoa) e uma chave privada (que deve ser mantida em segredo). O que é criptografado com uma chave só pode ser descriptografado com a outra. Esse sistema permite comunicação segura sem a necessidade de trocar senhas previamente e é amplamente usado em assinaturas digitais, certificados e conexões seguras.

A Criptografia Assimétrica (ou de Chave Pública) resolve o problema da troca de chaves da criptografia simétrica. Ela usa duas chaves distintas, mas matematicamente ligadas:

- **Chave Pública:** pode ser compartilhada com qualquer pessoa.
- **Chave Privada:** deve ser mantida em sigilo absoluto.

[2] Também chamado de Algoritmo de Chave Secreta, Chave Única, Chave Compartilhada, Chave Privada ou Criptografia Convencional.

02854629116 - Willian de Santana Angola

Essas chaves formam um par. O que uma criptografa, só a outra pode descriptografar. Para garantir a confidencialidade (sigilo): o emissor usa a chave pública do destinatário para criptografar a mensagem – apenas o destinatário, com sua chave privada, consegue ler a mensagem. Já para garantir autenticidade e não-repúdio: o emissor usa sua própria chave privada para criptografar – qualquer um pode usar sua chave pública para descriptografar e verificar que foi ele quem enviou.

Atenção: usar a chave privada do emissor não protege o sigilo, pois todos podem ler, mas confirma a identidade do autor e impede que ele negue ter enviado a mensagem (não-repúdio).

- **Principais algoritmos:** RSA, DSA, ECDSA, ElGamal, Diffie-Hellman (para troca de chaves), etc.

Comparando os algoritmos de criptografia simétrica com algoritmos de criptografia assimétrica, podemos afirmar que os algoritmos de criptografia simétrica possuem menor custo computacional do que a criptografia assimétrica (isto é, possuem um maior desempenho ao criptografar uma mesma quantidade de dados em menos tempo). Além disso, a criptografia simétrica utiliza, em geral, chaves menores do que a criptografia assimétrica.

Dito de outra forma, os algoritmos de criptografia assimétrica precisam – em geral – de chaves maiores para garantir o mesmo nível de segurança que algoritmos de criptografia simétrica (que utilizam chaves consideravelmente menores). Por fim, o gerenciamento de chaves para comunicação de um grupo de usuários é mais simples na criptografia assimétrica (utilizam 2n chaves, sendo n o número de pessoas), enquanto a criptografia simétrica utiliza n(n-1)/2 chaves.

Criptografia Híbrida

INCIDÊNCIA EM PROVA: BAIXÍSSIMA

A criptografia assimétrica possui vantagens importantes em relação à criptografia simétrica, como a facilidade no gerenciamento de chaves e a possibilidade de garantir autenticidade e não-repúdio. No entanto, ela também apresenta desvantagens, principalmente no desempenho. Em geral, as chaves assimétricas são bem maiores que as simétricas, o que torna os algoritmos assimétricos até cem vezes mais lentos.

Por esse motivo, é comum adotar a criptografia híbrida, que combina os dois métodos. Nesse modelo, a criptografia assimétrica é usada apenas para trocar, com segurança, as chaves simétricas, conhecidas como chaves de sessão. Após essa troca inicial, toda a comunicação é feita utilizando criptografia simétrica, que é mais rápida e eficiente. Protocolos como o SSL (Secure Sockets Layer) funcionam exatamente assim: usam a criptografia assimétrica para proteger a troca das chaves e, em seguida, utilizam a criptografia simétrica para garantir o sigilo e a integridade dos dados trocados durante a sessão.

Para concluir o tema, é essencial entender o Princípio de Kerckhoff. Esse princípio afirma que a segurança de um sistema criptográfico deve depender exclusivamente da chave utilizada, e não do segredo sobre o funcionamento do algoritmo. Em outras palavras, mesmo que um atacante conheça todos os detalhes do algoritmo, ele não deve ser capaz de quebrar a segurança do sistema sem a chave.

Na prática, isso significa que os algoritmos criptográficos devem ser públicos. E de fato são: basta uma busca na internet para encontrar a estrutura detalhada de algoritmos como AES, RSA ou Blowfish. A robustez de um algoritmo vem da sua resistência a ataques, mesmo após anos de exposição pública. Um algoritmo não se torna mais seguro por ser secreto – pelo contrário, sua confiabilidade cresce ao resistir a testes e tentativas de quebra ao longo do tempo.

Logo, a segurança está na chave, não no segredo do algoritmo. Isso é a base do Princípio de Kerckhoff. A segurança de um sistema criptográfico depende de três fatores principais:

02854629116 - Willian de Santana Angola

- **Força do Algoritmo:** algoritmos fracos ou simples são mais fáceis de quebrar;
- **Sigilo da Chave:** a chave privada ou secreta nunca deve ser exposta;
- **Comprimento da Chave:** chaves curtas são mais vulneráveis a ataques de força bruta.

Principais Algoritmos

INCIDÊNCIA EM PROVA: BAIXA

Vejamos agora uma tabela comparativa entre os principais algoritmos de criptografia simétrica e assimétrica:

ALGORITMO	DESCRIÇÃO
DES	Algoritmo simétrico de chave privada com 56 bits de tamanho de chave. Desenvolvido na década de 1970, é considerado fraco pelos padrões atuais de segurança.
3DES	Versão atualizada do DES, que usa três vezes a cifra DES para melhorar a segurança. Suas chaves podem ter 112 ou 168 bits.
AES	Algoritmo simétrico de chave privada que substituiu o DES como padrão de criptografia em 2001. Suas chaves podem ter 128, 192 ou 256 bits.
IDEA	Algoritmo simétrico de chave privada desenvolvido na década de 1990, com chave de 128 bits. Foi uma alternativa ao DES, mas é menos utilizado atualmente.
RC4	Algoritmo simétrico de chave privada usado em várias aplicações, como redes sem fio e SSL/TLS. Possui chaves de 40 a 2048 bits.
RSA	Algoritmo assimétrico de chave pública usado para criptografia e assinaturas digitais. É um dos algoritmos mais amplamente usados na criptografia moderna.
DIFFIE-HELLMAN	Algoritmo de troca de chaves que permite a comunicação segura em um canal inseguro. É amplamente utilizado em sistemas criptográficos baseados em chave pública.
BLOWFISH	Algoritmo simétrico de chave privada usado em diversas aplicações de segurança, com chaves de 32 a 448 bits. É conhecido por sua velocidade e segurança.

ALGORITMO	SEGURANÇA	VELOCIDADE	TAMANHO DA CHAVE	UTILIZAÇÃO	TIPO
DES	Fraco	Rápido	56 bits	Legado	Simétrico
3DES	Moderado	Lento	112-168 bits	Legado	Simétrico
AES	Forte	Rápido	128-256 bits	Atual	Simétrico
IDEA	Moderado	Rápido	128 bits	Legado	Simétrico
RC4	Moderado	Rápido	40-2048 bits	Legado	Simétrico
RSA	Forte	Lento	2048-4096 bits	Atual	Assimétrico
DIFFIE-HELLMAN	Forte	Moderado	Variável	Chave Pública	Assimétrico
BLOWFISH	Forte	Rápido	32-448 bits	Legado	Simétrico

02854629116 - Willian de Santana Angola

AUTENTICIDADE

Conceitos Básicos

INCIDÊNCIA EM PROVA: BAIXA

A autenticidade é um dos pilares fundamentais da segurança da informação e diz respeito à garantia de que uma informação, transação ou comunicação é realmente proveniente de quem declara tê-la originado. Em um mundo cada vez mais digital, onde interações ocorrem à distância e dados circulam constantemente, assegurar a autenticidade é essencial para evitar fraudes, acessos não autorizados e manipulação de informações.

Nesse tópico, veremos os principais métodos de autenticação. Os métodos de autenticação são técnicas utilizadas para verificar a identidade de um usuário ao acessar um sistema ou serviço. Eles se baseiam em três categorias principais: "o que você sabe", "o que você tem" e "o que você é". Cada uma dessas formas oferece um nível diferente de segurança e, quando combinadas (como na autenticação multifator), tornam o processo de verificação muito mais robusto.



Método de Autenticação: O que você sabe?

Esse tipo de autenticação baseia-se em informações que apenas o usuário deveria saber, como senhas, PINs (números de identificação pessoal), respostas a perguntas de segurança e códigos de acesso. É o método mais comum e amplamente utilizado. No entanto, também é o mais vulnerável, já que senhas fracas, reutilizadas ou expostas em vazamentos podem ser facilmente exploradas por atacantes. Por isso, é fundamental o uso de senhas fortes, atualizações periódicas e boas práticas de armazenamento.

Senhas

A forma mais comum de autenticação ainda é a tradicional combinação de usuário e senha, por ser simples e fácil de usar. No entanto, essa praticidade traz riscos, principalmente quando se utilizam senhas

02854629116 - Willian de Santana Angola

fracas, como “12345” ou “senha123”. Senhas curtas e simples podem ser facilmente descobertas por ataques de força bruta, em que o sistema tenta todas as combinações possíveis até acertar. Um computador pode testar centenas de milhares de senhas em segundos.

Para aumentar a segurança, é essencial: usar senhas longas e complexas (com letras maiúsculas, minúsculas, números e símbolos); evitar repetir senhas em diferentes serviços; e ativar a autenticação em dois fatores (2FA), que adiciona uma camada extra de proteção. Medidas como bloqueio temporário após várias tentativas incorretas e políticas de senha forte ajudam a dificultar ataques e proteger seus dados. Vocês já devem ter visto algumas estratégias de criação de senhas mais ou menos assim:

ESTRATÉGIAS DE SENHAS	DESCRIÇÃO
USE SENHAS LONGAS	Quanto maior a senha, mais difícil de quebrar. Recomenda-se no mínimo 12 a 14 caracteres.
MISTURE DIFERENTES TIPOS DE CARACTERES	Utilize letras maiúsculas, minúsculas, números e símbolos para aumentar a complexidade.
EVITE PALAVRAS COMUNS OU SEQUÊNCIAS ÓBVIAS	Não use senhas como "123456", "senha", "admin", "abcdef" ou datas de nascimento.
CRIE FRASES-SENHA (PASSPHRASES)	Use uma frase fácil de lembrar, mas difícil de adivinhar, como “Sol&Chuva1987!CaféQuente”.
NÃO REUTILIZE SENHAS	Cada conta deve ter uma senha única, para evitar vazamentos em cadeia.
EVITE INFORMAÇÕES PESSOAIS	Não use nomes, aniversários, placas de carro ou qualquer dado facilmente associável a você.
USE GERENCIADORES DE SENHAS	Ferramentas como Bitwarden, 1Password ou LastPass ajudam a criar e armazenar senhas fortes.
ATIVE A AUTENTICAÇÃO EM DOIS FATORES (2FA)	Complementa a senha com um segundo fator, como código por app ou biometria.
ATUALIZE SENHAS PERIODICAMENTE	Troque senhas antigas, especialmente se houver suspeita de vazamento.
TESTE A FORÇA DA SENHA	Utilize ferramentas confiáveis para verificar se a senha é forte o suficiente.

Uma senha de oito dígitos numéricos tem apenas um milhão de combinações possíveis – é ridiculamente fácil para um computador testar todas as possibilidades em pouco tempo utilizando um ataque de força bruta. No entanto, uma senha de oito caracteres que podem ser números, símbolos, maiúsculos, minúsculos, entre outros, pode ter mais de 600 trilhões de combinações. Aí fica bem mais complexo para qualquer computador pessoal!

PIN

O PIN (Personal Identification Number) é um número de identificação pessoal usado como forma de autenticação baseada em algo que você sabe. É comum em caixas eletrônicos, cartões, celulares e sistemas que exigem agilidade, já que é mais curto que uma senha tradicional. Por ser simples, muitos usuários escolhem combinações fracas como “1234” ou “0000”, o que compromete a segurança. Sempre que possível, use PINs mais longos e imprevisíveis.

O PIN também é utilizado em autenticação de dois fatores, como em cartões com chip: o cartão é “algo que você tem” e o PIN é “algo que você sabe”. Essa combinação fortalece a proteção contra acessos não autorizados. Além disso, dispositivos modernos usam o PIN para desbloqueio rápido e impõem limites de tentativas e bloqueios temporários após erros, dificultando ataques.

Perguntas de Segurança

02854629116 - Willian de Santana Angola

As perguntas de segurança são um método de autenticação baseado em algo que você sabe. Geralmente usadas para recuperação de contas, elas solicitam respostas a perguntas pessoais definidas no momento do cadastro, como "Qual o nome do seu primeiro pet?" ou "Em que escola estudou?". Apesar de parecerem seguras, esse método tem diversas fragilidades. Muitas respostas são fáceis de descobrir, principalmente com as informações pessoais publicadas em redes sociais. Além disso, usuários costumam escolher respostas genéricas ou fáceis de adivinhar.

Outro problema são erros de digitação ou variações na escrita, que podem bloquear o acesso mesmo de quem forneceu a resposta original. Por isso, embora ainda utilizadas como etapas adicionais, as perguntas de segurança não devem ser o único método de autenticação. Quando usadas, devem ser configuradas com respostas criativas e difíceis de adivinhar.

Método de Autenticação: O que você é?

Esse tipo de autenticação usa características físicas ou comportamentais do usuário, ou seja, dados biométricos. Exemplos incluem impressão digital, reconhecimento facial, leitura de íris, reconhecimento de voz e até padrões de digitação. Esse método é altamente seguro, pois as características biométricas são únicas para cada indivíduo. No entanto, ele também levanta preocupações quanto à privacidade e à possibilidade de falsificação em sistemas mal projetados.

Biometria

Biometria é a medição de características biológicas utilizadas para identificação pessoal. O termo vem do grego: "bio" (vida) + "metria" (medida). O exemplo mais comum é a impressão digital, usada para desbloquear celulares e computadores. Mas a biometria vai além: inclui reconhecimento facial, de voz, íris, retina, veias da mão e até DNA. Essas características são únicas em cada pessoa, o que torna esse método de autenticação seguro e difícil de falsificar. Por isso, a biometria é cada vez mais usada em sistemas operacionais, apps bancários, controle de acesso em prédios, aeroportos e outros. Além de aumentar a segurança, dispensa o uso de senhas, facilitando o dia a dia do usuário.

Método de Autenticação: O que você tem?

Esse método se baseia em algo físico ou digital que o usuário possui, como um token, um cartão de acesso, um smartphone com aplicativo autenticador (como Google Authenticator), ou ainda um código enviado por SMS ou e-mail. Ele é bastante utilizado em sistemas de autenticação em dois fatores (2FA), oferecendo uma camada adicional de segurança. Mesmo que a senha do usuário seja comprometida, o invasor ainda precisaria ter acesso ao dispositivo ou objeto para concluir o login.

Smart Cards

Smartcards, ou cartões inteligentes, são cartões físicos com um chip embutido que armazena dados criptografados. Baseiam-se em "algo que você tem" e são amplamente usados em ambientes com alta exigência de segurança, como empresas, órgãos públicos e instituições militares. Esses cartões podem conter certificados digitais, chaves criptográficas e dados pessoais. Para funcionar, precisam ser inseridos em um leitor específico, geralmente conectado ao computador. Normalmente, também exigem o uso de uma senha ou PIN, formando uma autenticação de dois fatores (cartão + senha).

Sua principal vantagem é a alta segurança, já que os dados são protegidos por criptografia no chip, dificultando clonagem ou roubo de informações. Os smartcards são usados para: login seguro em sistemas; assinatura digital; controle de acesso físico a áreas restritas; e autenticação em redes

02854629116 - Willian de Santana Angola

corporativas. Um exemplo prático são os crachás com chip, comuns em empresas e universidades, que servem tanto para identificação visual quanto para controle digital de acesso.

Aplicativos Autenticadores

Aplicativos autenticadores são uma forma de autenticação baseada em "algo que você tem" e são amplamente usados em verificação em dois fatores (2FA). Eles geram códigos temporários (OTP – One-Time Password) que mudam a cada poucos segundos e são utilizados como uma segunda etapa no login. Assim, o usuário digita sua senha (algo que sabe) e depois o código do app (algo que tem). Esses códigos são gerados no próprio celular, sem depender de internet ou sinal, o que evita riscos como interceptação de SMS, clonagem de chip ou atrasos. Aplicativos populares incluem: Google Authenticator, Microsoft Authenticator, Authy e LastPass Authenticator.

A configuração é simples: o usuário escaneia um QR Code fornecido pelo serviço, e o app começa a gerar os códigos automaticamente. Alguns desses apps também oferecem proteção por senha, biometria e backup criptografado, o que facilita a recuperação em caso de perda do celular. Os OTPs são gerados com base em dois algoritmos:

- **TOTP (Time-Based One-Time Password):** muda a cada 30 ou 60 segundos.
- **HOTP (HMAC-Based One-Time Password):** muda com base no número de acessos.

Esses códigos são imprevisíveis, sincronizados e funcionam apenas por um curto período, tornando-os altamente seguros. Como não são armazenados, mesmo que alguém veja o código, não poderá reutilizá-lo. Atenção: códigos enviados por SMS ou e-mail são menos seguros, pois podem ser interceptados. Os métodos mais recomendados atualmente são os apps autenticadores e tokens físicos.

Tokens

Tokens são dispositivos físicos ou digitais usados como forma de autenticação baseada em "algo que você tem", sendo muito comuns na verificação em dois fatores (2FA). Após digitar a senha (algo que você sabe), o usuário precisa inserir o código temporário gerado pelo token para completar o acesso. Existem dois tipos principais:

- **Tokens Físicos (Hardware):** geralmente parecem um chaveiro ou um cartão com visor, e geram códigos numéricos que mudam a cada 30 segundos ou permitem autenticação via porta USB.

- **Tokens Digitais (Sofware):** funcionam por meio de aplicativos autenticadores (Ex: Google/Microsoft Authenticator ou o próprio app do seu banco) – geram códigos temporários e únicos.

Esses tokens usam os algoritmos TOTP ou HOTP, que garantem que os códigos sejam únicos e temporários, dificultando invasões mesmo que a senha seja descoberta. Importante: o envio de códigos por SMS ainda é usado, mas não é o método mais seguro devido ao risco de interceptação. Hoje, os métodos mais recomendados são aplicativos autenticadores e tokens físicos dedicados, como o YubiKey, especialmente em ambientes que exigem alto nível de segurança.

Autenticação Forte

INCIDÊNCIA EM PROVA: BAIXA

02854629116 - Willian de Santana Angola

Autenticação Forte[3] é é o processo de verificação da identidade de um usuário que exige o uso de dois ou mais fatores distintos. Isso aumenta significativamente a segurança e reduz o risco de acessos indevidos, mesmo que uma das credenciais (como a senha) seja comprometida. É comum em ambientes corporativos, bancários, governamentais e também em serviços online. Exemplos de autenticação forte: Senha + Código de Aplicativo Autenticador ou Biometria + Smartcard.

A combinação de fatores dificulta ataques como phishing, força bruta, vazamento de senhas e engenharia social, já que o invasor precisaria ter acesso a todos os elementos de autenticação ao mesmo tempo. Autenticação em Dois Fatores (2FA) é um tipo de autenticação forte que exige exatamente dois fatores diferentes para validar o acesso. Normalmente, combina: Algo que você sabe (senha) com algo que você tem (como um código no celular ou um token) ou algo que você é (como biometria).

Exemplo comum: login com senha + código enviado para o celular. Outro: uso do cartão no caixa eletrônico (algo que você tem) + senha ou digital (algo que você sabe ou é).

Assinatura Digital

Conceitos Básicos

INCIDÊNCIA EM PROVA: ALTÍSSIMA

Assinar documentos em papel se tornou lento e inseguro. Casos de falsificação de assinaturas e perdas por incêndios em cartórios mostram a fragilidade do modelo tradicional. Em um mundo digital, precisamos de soluções ágeis e seguras – como a assinatura digital. Imagine um contrato entre duas pessoas em países diferentes. Com a assinatura digital, o documento é assinado e enviado em minutos, sem papel e com validade legal. Isso é possível graças à criptografia assimétrica: ao assinar com sua chave privada, o remetente garante autenticidade; e quem possui a chave pública pode verificar a assinatura.

A assinatura digital garante três princípios fundamentais: Autenticidade (confirma a identidade do autor); Integridade (assegura que o conteúdo não foi alterado após a assinatura); e Irretratabilidade (impede que o autor negue ter assinado o documento). Para isso, utiliza-se uma função hash, que transforma qualquer dado (texto, imagem, etc.) em uma sequência de tamanho fixo. Mesmo pequenas alterações no conteúdo geram hashes totalmente diferentes, funcionando como uma "impressão digital" do arquivo. Assim, se o conteúdo for alterado, a assinatura digital deixa de ser válida – revelando qualquer tentativa de fraude.

Funções de hash transformam qualquer entrada (texto, imagem, arquivo, etc.) em uma sequência de saída com tamanho fixo. Essa saída funciona como uma "impressão digital" do conteúdo. Mesmo que a entrada tenha milhares de caracteres, o hash sempre gera uma saída curta e padronizada. Se houver qualquer alteração na entrada, o hash muda completamente, o que permite verificar se um conteúdo foi modificado. Essa lógica é usada, por exemplo: em boletos bancários, com o dígito verificador; no CPF, onde os dois últimos dígitos são calculados com base nos anteriores.

O hash é uma função unidirecional: você gera a saída a partir da entrada, mas não consegue descobrir a entrada pela saída, o que aumenta a segurança. Outra propriedade importante é a consistência: a mesma entrada sempre gera a mesma saída. Mas há uma limitação chamada colisão, que ocorre quando duas

[3] Muitas vezes, as bancas utilizam os termos Autenticação Forte e Autenticação Multifator (MFA) de forma intercambiável. Sendo tecnicamente rigoroso, a diferença entre eles é que o primeiro exige que os fatores sejam de categorias diferentes e o segundo permite que os fatores sejam da mesma categoria ou não. Toda autenticação forte é multifator, mas nem toda autenticação multifator é forte. No entanto, muitas vezes as bancas vão considerar ambos como sinônimos.

02854629116 - Willian de Santana Angola

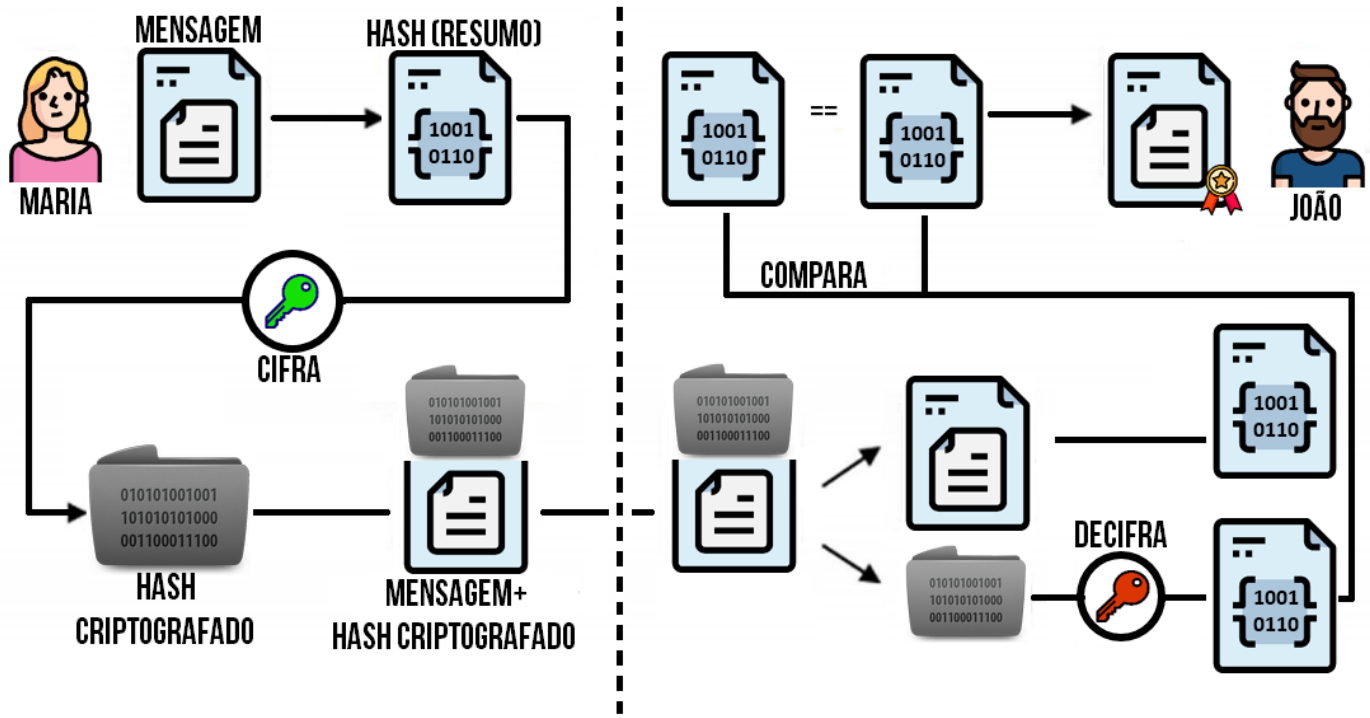
entradas diferentes geram o mesmo hash. Em algoritmos fracos, como a função "resto da divisão", colisões são comuns e comprometem a segurança.

Para minimizar esse risco, algoritmos de hash modernos utilizam saídas maiores – como 128 bits ou mais – o que torna as colisões extremamente raras. Exemplo: o algoritmo MD5 gera saídas de 128 bits, mas já não é mais recomendado para segurança devido à descoberta de colisões. Ainda assim, é útil para fins didáticos.

Dito tudo isso, fica a pergunta: qual é a relação entre Algoritmo de Hash e Assinatura Digital? Nosso objetivo é garantir Autenticidade, Integridade e Irretratabilidade do emissor. Nós já sabemos que – para garantir autenticidade – basta utilizar a Criptografia Assimétrica e cifrar a informação com a minha chave privada. Nós também sabemos que – para garantir a integridade – basta utilizar um Algoritmo de *Hash*. Então, combinamos essas duas estratégias para alcançar nosso objetivo.

Vejam na imagem seguinte que Maria escreve sua mensagem original, em texto claro (sem criptografia). Em seguida, ela gera o hash da mensagem – ou seja, um resumo digital. Agora vem o segredo: ela criptografa esse hash com a sua chave privada (isso é o que chamamos de assinatura digital). Por fim, ela envia para João: a mensagem original + o hash criptografado (a assinatura).

Do lado de João, ele recebe a mensagem e o hash criptografado e faz duas coisas: primeiro, ele gera um novo hash da mensagem que recebeu; depois, ele descriptografa o hash original (a assinatura) usando a chave pública da Maria. Agora, portanto, ele tem dois hashes: um que ele mesmo calculou e outro que foi enviado e assinado pela Maria. Se os dois valores forem iguais, temos que: a mensagem não foi modificada (garantia de integridade) e a mensagem foi assinada com a chave privada da Maria (garantia de autenticidade). Logo, Maria não pode negar que enviou (garantia de irretratabilidade).



02854629116 - Willian de Santana Angola



Um detalhe importante: a assinatura digital não tem como foco a confidencialidade. A mensagem enviada não é criptografada, portanto qualquer pessoa pode lê-la. O objetivo principal é provar a autenticidade do remetente, a integridade da mensagem e garantir o não-repúdio. Isso é possível porque somente a chave pública de Maria pode verificar algo criptografado com a chave privada dela, confirmando sua autoria.

Um ponto importante: o algoritmo de hash não criptografa o conteúdo. Ele apenas gera um resumo (impressão digital) da mensagem. O que realmente é criptografado é esse hash, utilizando a chave privada do emissor. Resumo do processo: o emissor gera o hash da mensagem; criptografa o hash com sua chave privada (assinatura digital); e envia a mensagem em texto claro + hash criptografado. Já o destinatário gera o hash da mensagem recebida; descriptografa o hash com a chave pública do remetente; compara os hashes; e se os hashes forem iguais: a mensagem não foi alterada (integridade), foi assinada pelo remetente (autenticidade) e O remetente não pode negar autoria (irretratabilidade).

Algoritmos de Hash

INCIDÊNCIA EM PROVA: MÉDIA

Os algoritmos de hash são funções criptográficas fundamentais na segurança da informação, utilizadas para gerar um resumo (ou impressão digital) de dados, como senhas, arquivos e mensagens. Eles desempenham um papel crucial em processos como verificação de integridade, autenticação, assinatura digital e armazenamento seguro de credenciais. Neste tópico, vamos conhecer os principais algoritmos de hash utilizados atualmente, entender suas características, aplicações e o motivo pelo qual alguns deles foram considerados inseguros ao longo do tempo, sendo substituídos por versões mais robustas.

MD5

O MD5 é um algoritmo de hash criado em 1991 para gerar um resumo fixo de 128 bits, independentemente do tamanho da entrada. Foi amplamente utilizado para verificar integridade de arquivos, autenticação, assinaturas digitais e armazenamento de senhas. Porém, com o tempo, foram descobertas vulnerabilidades graves, especialmente colisões – ou seja, duas entradas diferentes gerando o mesmo hash. Isso compromete a integridade e autenticidade dos dados, tornando o MD5 inadequado para aplicações de segurança, como autenticação, certificação digital e proteção de senhas.

Hoje, algoritmos como SHA-256 e SHA-3 são os mais recomendados por sua maior segurança. O MD5 ainda é usado em sistemas antigos ou para tarefas simples, como verificação de integridade de arquivos, mas não deve ser usado em contextos que exigem segurança.

SHA-1

O SHA-1 é um algoritmo de hash criado pela NSA em 1995, com saída fixa de 160 bits. Foi amplamente utilizado em assinaturas digitais, certificados SSL/TLS, verificação de integridade e autenticação. Apesar

02854629116 - Willian de Santana Angola

de ser unidirecional e determinístico, perdeu credibilidade após ser comprovada a possibilidade de colisões – especialmente após o Google demonstrar, em 2017, duas entradas diferentes com o mesmo hash. Isso inviabiliza seu uso em segurança da informação.

Hoje, o SHA-1 é considerado obsoleto e inseguro. Organizações como NIST, Microsoft e Google desaconselham seu uso. O recomendado é adotar algoritmos da família SHA-2, como o SHA-256 ou SHA-512, mais robustos contra-ataques. O SHA-1 só aparece, eventualmente, em sistemas legados, mas não deve ser usado em contextos sensíveis.

SHA-256

O SHA-256 é um algoritmo de hash da família SHA-2, criado pela NSA, com saída fixa de 256 bits. É seguro, unidirecional, determinístico e resistente a colisões. Até hoje, nenhuma colisão prática foi identificada. É amplamente usado em: blockchain (ex: Bitcoin), certificados digitais (SSL/TLS), assinaturas digitais e armazenamento de senhas (com salting e stretching). Apesar de exigir mais processamento que algoritmos antigos, é o padrão atual para aplicações que exigem alto nível de segurança.

Por fim, é importante destacar o papel do hash no contexto de investigações criminais. Em processos judiciais, a evidência digital (arquivos, e-mails, logs, imagens de disco) deve ser tratada com o máximo rigor para ser aceita como prova. Aí que entra o conceito de Cadeia de Custódia, que é uma sequência de proteção e guarda (custódia) dos elementos materiais encontrados durante uma investigação e que devem manter as suas características originais e informações íntegras, sem deixar dúvidas sobre a sua origem e manuseios realizados. E o hash é o elo inquebrável que garante a integridade da evidência em cada etapa da cadeia de custódia.

O primeiro (e mais crítico) passo na coleta de evidência digital é a criação de uma imagem forense (cópia bit a bit) do dispositivo original (disco rígido, celular, pendrive, entre outros). Antes de iniciar a cópia, o perito forense calcula o hash do dispositivo original. O dispositivo é copiado, bit a bit, para um novo dispositivo de armazenamento (chamado imagem forense). Então, o hash da imagem forense é calculado. Se o hash do dispositivo original e o hash da imagem forense forem iguais, significa que a imagem forense é uma cópia exata e inalterada do dispositivo original.

Em cada etapa subsequente da investigação, o hash da evidência é registrado: tanto na transferência (quando a evidência é transferida do local de coleta para o laboratório, o hash é verificado); quanto na análise (antes e depois de qualquer análise – como a extração de dados ou a execução de scripts –, o hash é verificado para provar que a análise não alterou a evidência); ou na apresentação em tribunal (o perito apresenta o hash original e o hash final da evidência, provando ao juiz que o material analisado é exatamente o mesmo que foi coletado na cena do crime).

Podemos dizer, portanto, que no campo da forense e da segurança, o hash é o selo de autenticidade que transforma um arquivo digital em uma evidência legalmente admissível. Sem a garantia de integridade fornecida por algoritmos como o SHA-256, a evidência digital seria facilmente contestável, minando a credibilidade de qualquer investigação.

Controle de Acesso

INCIDÊNCIA EM PROVA: BAIXA

02854629116 - Willian de Santana Angola



O Controle de Acesso é um conjunto de práticas e tecnologias que garantem que apenas usuários autorizados possam acessar sistemas, redes e informações digitais. Ele envolve processos como identificação, autenticação e autorização, permitindo que organizações protejam seus dados contra acessos não autorizados. Com o avanço da tecnologia e o aumento das ameaças cibernéticas, métodos modernos como autenticação multifator, biometria e permissões baseadas em funções têm se tornado essenciais para reforçar a segurança digital.

Identificação

Primeira etapa do controle de acesso. O usuário declara sua identidade por meio de login, CPF, e-mail, etc. O sistema apenas registra quem está tentando acessar, sem verificar se é verdadeiro.

Autenticação

Etapa que valida a identidade informada. O sistema exige uma prova, como senha, biometria ou token. Pode ser feita com um fator (senha) ou múltiplos (senha + biometria).

Autorização

Após autenticar, o sistema define o que o usuário pode fazer. Permissões são atribuídas com base em perfis, cargos ou regras. Evita acessos indevidos a funções ou dados.

ASPECTO	IDENTIFICAÇÃO	AUTENTICAÇÃO	AUTORIZAÇÃO
DEFINIÇÃO	Processo pelo qual um usuário se apresenta ao sistema.	Verificação de identidade do usuário para garantir que ele é quem diz ser.	Processo que define os privilégios e permissões do usuário dentro do sistema.
EXEMPLO	Nome de usuário, número de matrícula, e-mail.	Senha, biometria, autenticação em dois fatores.	Permissão para modificar configurações, acessar arquivos e executar ações.
OBJETIVO	Reconhecer quem está tentando acessar o sistema.	Garantir que a pessoa identificada é realmente quem diz ser.	Controlar o que um usuário pode ou não pode fazer dentro do sistema.
FATOR DE SEGURANÇA	Baixo – apenas identifica o usuário, sem validar sua identidade.	Médio – exige prova de identidade para garantir acesso.	Alto – limita as ações de um usuário mesmo após autenticação bem-sucedida.

02854629116 - Willian de Santana Angola

MOMENTO DE USO	Primeira etapa do acesso a um sistema.	Segunda etapa, logo após a identificação.	Aplicado após autenticação bem-sucedida para restringir ou conceder acesso.

Certificado Digital

Conceitos Básicos

INCIDÊNCIA EM PROVA: ALTÍSSIMA

A assinatura digital garante autenticidade, integridade e irretratabilidade, mas tem um problema: é difícil saber se a chave pública recebida é realmente de quem diz ser. Um atacante pode interceptar a mensagem, substituí-la e enviar sua própria chave pública, enganando o destinatário.

Para resolver isso, utiliza-se uma Autoridade Certificadora (AC), uma entidade confiável que emite certificados digitais. Esses certificados associam a chave pública a seu verdadeiro dono, incluindo dados como nome, chave pública, validade e a assinatura digital da AC. Assim como cartórios validam assinaturas físicas, a AC valida assinaturas digitais.

Navegadores possuem uma lista de ACs confiáveis. Ao acessar um site com HTTPS, o navegador verifica se o certificado do site foi emitido por uma dessas ACs. Se for válido, aparece o cadeado na barra de endereço, indicando comunicação criptografada e autenticidade do servidor.

A AC também é responsável por revogar certificados comprometidos e manter listas de certificados não confiáveis. Sempre que ela descobre ou é informada de que um certificado não é mais confiável, ela o inclui em uma "Lista Negra", chamada de Lista de Certificados Revogados (LCR). A LCR é um arquivo eletrônico publicado periodicamente pela Autoridade Certificadora, contendo o número de série dos certificados que não são mais válidos e a data de revogação. Quando isso ocorre, geralmente aparece a mensagem abaixo ao tentar acessar um site.



Por fim, falemos sobre EV-SSL (Extended Validation)! Eles são tipos especiais de certificados digitais X.509 que requerem algumas exigências a mais de segurança para serem emitidos, tais como recursos visuais na barra de endereço do navegador. *Quem nunca viu uma barrinha verde ao lado do endereço?* Isso

02854629116 - Willian de Santana Angola

significa que não se trata de um certificado comum, mas de um certificado EV-SSL – que possui uma segurança maior!

Eu recebo frequentemente algumas perguntas no fórum de dúvidas, logo vamos saná-las de uma vez por todas. A primeira é sobre a diferença entre assinatura digital e certificado digital:

ASPECTO	ASSINATURA DIGITAL	CERTIFICADO DIGITAL
DEFINIÇÃO	Método matemática de autenticação que garante a integridade e autenticidade de uma entidade.	Documento eletrônico assinado digitalmente que vincula uma chave pública a uma entidade.
OBJETIVO	Validar a autoria e garantir que o documento não foi alterado após a assinatura.	Identificar e autenticar digitalmente um usuário ou entidade.
USO	Assinar contratos, documentos e transações digitais com validade jurídica.	Emitir assinaturas digitais, acessar sistemas seguros e realizar transações online.
DEPENDÊNCIA	Necessita de um certificado digital para ser gerada.	Emitido por uma Autoridade Certificadora e usado para autenticação e assinatura digital.
SEGURANÇA	Utiliza criptografia para garantir que o documento não seja alterado após a assinatura.	Contém chaves criptográficas que garantem a identidade do titular e a segurança das transações.
VALIDADE JURÍDICA	Possui validade jurídica quando vinculada a um certificado digital reconhecido.	Tem validade jurídica e pode ser usado para autenticação em serviços governamentais e empresariais.

Outra dúvida que sempre aparece é: "Professor, a chave privada fica dentro do certificado digital?" E a resposta é: não! O certificado é público, usado por sistemas para validar assinaturas, e não pode conter a chave privada, que deve ser mantida em segredo. A chave privada pode ser armazenada de três formas: no computador (menos seguro); em token USB (mais seguro); e em smartcard com chip. Tokens e smartcards geralmente armazenam o certificado e a chave privada. A chave privada fica protegida por senha. Você não precisa decorar a chave privada, apenas a senha que permite seu uso para assinar documentos ou acessar sistemas seguros. Vejamos um exemplo de chave privada:

```
-----BEGIN PRIVATE KEY-----

MDJKoZIAQ5MCAhvcNAQEBBQADKgAwDXcZ3OBJwlgYjDE7cZ83SO3QZZSfTiwvXqBezakBQsjQVZ1h5MCfTiwvw
lgYAwEAAQ==XVOAoZIhvcNgEAAiBimNdWkSETIbtxnzc7dBliCNBvj9qTgjQVwjSEgwEgjQVZSjQzc7dBlipLS
fh5pLBjSMiGOdWCAlaQVZgYCAlghvcNAQEBYjDXVMINjDXVcNADKgAvXqBezSfTiwvKAQEBBQDQY5MCbtxnCKo
ZkBjSE7cZMoZIhVVjQVZSvj9qTgjQzc7BKgAwDwEgjQVZSjSE7cZMZIhvcNggjQVO3QZoZIAAwEAAQEBBAiBiZ
83Se1

-----END PRIVATE KEY-----
```

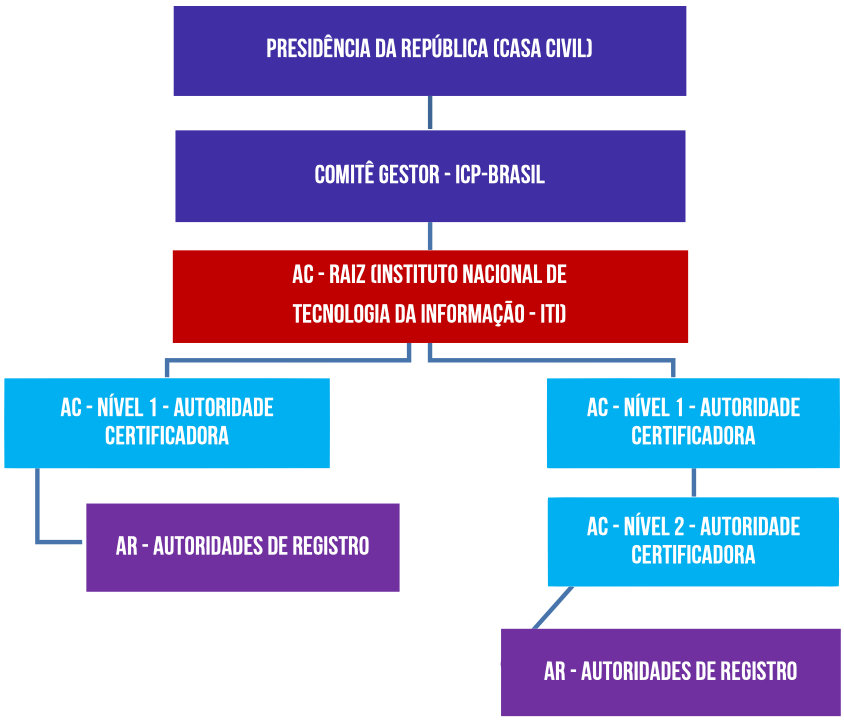
Infraestrutura de Chave Pública (ICP-Brasil)

INCIDÊNCIA EM PROVA: MÉDIA

Uma Autoridade Certificadora (AC) emite certificados digitais e também possui seu próprio certificado digital, com sua chave pública. Mas quem emite esse certificado para a AC? É aí que entra a Infraestrutura de Chaves Públicas (ICP). A ICP é uma estrutura pública ou privada que garante confiança no uso de certificados digitais. Ela funciona como uma terceira parte confiável, permitindo a validação segura da identidade de quem envia mensagens ou realiza transações.

02854629116 - Willian de Santana Angola

A ICP é composta por técnicas, práticas e procedimentos que dão base à certificação digital, garantindo autenticidade, integridade e validade jurídica. No Brasil, essa estrutura é chamada ICP-Brasil. A ICP envolve dois tipos principais de entidades: Autoridades Certificadoras (AC), que emitem certificados digitais; e Autoridades de Registro (AR): fazem a interface com os usuários e vendem os certificados. Vejam a cadeia de certificação:



Sabe quando vamos tirar a carteira de identidade? Pois é, a maioria das pessoas procura a Secretaria de Segurança Pública (SSP), que é responsável por expedir um documento oficial de identificação atestando quem você realmente é – seria análogo a uma Autoridade Certificadora de Nível 1. Ela está subordinada ao Ministério da Justiça, análogo a Autoridade Certificadora Raiz. Já o Instituto de Identificação da SSP seria a Autoridade de Registro.



02854629116 - Willian de Santana Angola

- **Autoridade Certificadora Raiz**

Trata-se da primeira autoridade da cadeia de certificação. Ela é responsável por executar as políticas de certificados e as normas técnicas e operacionais aprovadas pelo Comitê Gestor da ICP-Brasil. Dessa forma, compete à AC-Raiz emitir, expedir, distribuir, revogar e gerenciar os certificados das autoridades certificadoras de nível imediatamente subsequente ao seu – isso costuma cair em prova.

A AC-Raiz também está encarregada de emitir a Lista de Certificados Revogados (LCR) e de fiscalizar e auditar as Autoridades Certificadoras – ACs, Autoridades de Registro – ARs e demais prestadores de serviço habilitados na ICP-Brasil. Além disso, ela é responsável por verificar se as ACs estão atuando em conformidade com as diretrizes e normas técnicas estabelecidas pelo Comitê Gestor da ICP-Brasil.

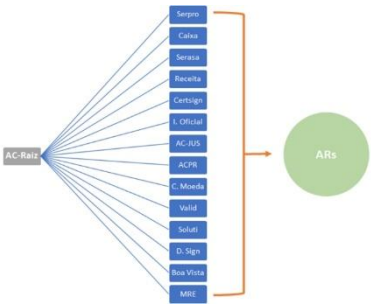
- **Autoridade Certificadora**

Trata-se de uma entidade, pública ou privada, subordinada à hierarquia da ICP-Brasil, responsável por emitir, distribuir, renovar, revogar e gerenciar certificados digitais. Busca verificar se o titular do certificado possui a chave privada que corresponde à chave pública do certificado. Ela cria e assina digitalmente o certificado do assinante, onde o certificado emitido pela AC representa a declaração da identidade do titular, que possui um par único de chaves.

Cabe também à Autoridade Certificadora emitir Listas de Certificados Revogados (LCR) e manter registros de suas operações sempre obedecendo às práticas definidas na Declaração de Práticas de Certificação – DPC. Além de estabelecer e fazer cumprir, pelas Autoridades de Registro – ARs a ela vinculadas, as políticas de segurança necessárias para garantir a autenticidade da identificação realizada.

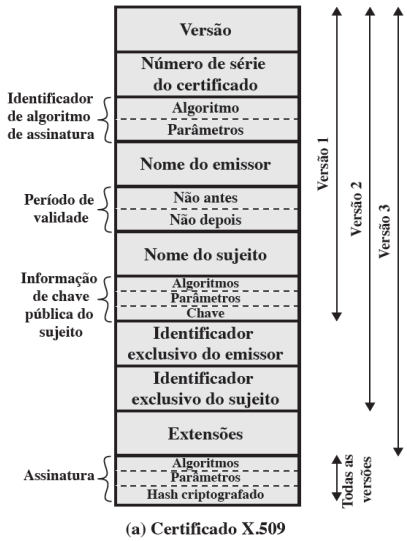
- **Autoridade de Registro**

Trata-se de uma entidade responsável pela interface entre o usuário e a Autoridade Certificadora. Vinculada a uma AC, tem por objetivo o recebimento, a validação, o encaminhamento de solicitações de emissão ou revogação de certificados digitais e identificação, de forma presencial, de seus solicitantes. É responsabilidade da AR manter registros de suas operações. Pode estar fisicamente localizada em uma AC ou ser uma entidade de registro remota. A imagem ao lado mostra um exemplo de organização.



Em suma: a Autoridade Certificadora Raiz emite certificados digitais para as Autoridades Certificadoras hierarquicamente abaixo dela, que emitem certificados para equipamentos, pessoas físicas ou jurídicas. As Autoridades de Registro não emitem certificados digitais. Elas o recebem, validam ou encaminham e guardam um registro dessas operações. *Quem emite certificado para pessoas físicas?* Apenas a Autoridade Certificadora!

02854629116 - Willian de Santana Angola



(a) Certificado X.509

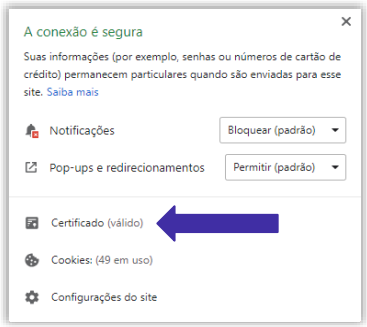
É importante ressaltar que existe um padrão para Infraestrutura de Chaves Públicas! O Padrão X.509 (Versão 3) especifica, entre outras coisas, o formato dos certificados digitais, de tal maneira que se possa amarrar firmemente um nome a uma chave pública – esse é o padrão utilizado pela ICP-Brasil! *Professor, quais campos existem dentro de um certificado digital?* Existem diversos campos, sendo que nem todos são obrigatórios.

Os campos são: versão, número de série, tipo de algoritmo, nome do algoritmo, nome do titular, nome do emissor, data de validade, chave pública, assinatura da autoridade certificadora, identificador da chave do titular, identificador da chave do emissor, além de diversos atributos ou extensões – vocês não precisam se preocupar em decorar esses campos. *Você quer ver um certificado digital?* Vou mostrar como você pode acessá-lo...

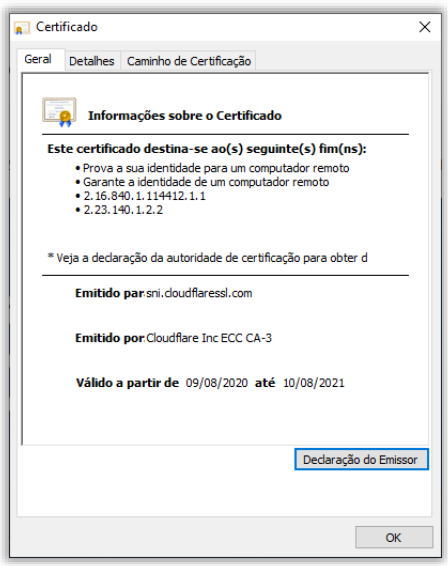
Abra o seu navegador favorito (Ex: Chrome, Edge, Firefox) e acesse na barra de endereços alguma página web via HTTPS.

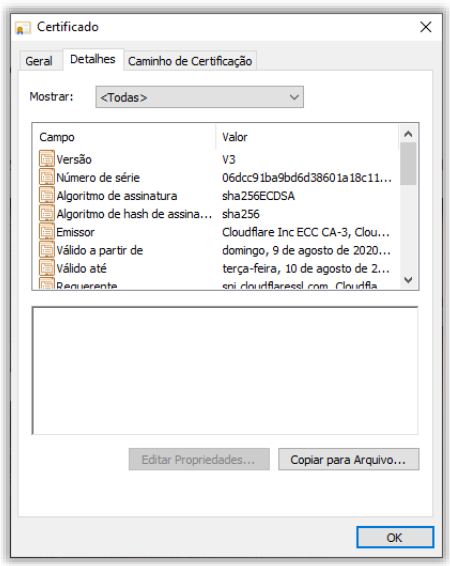
Por exemplo: *https://www.estrategiaconcursos.com.br*

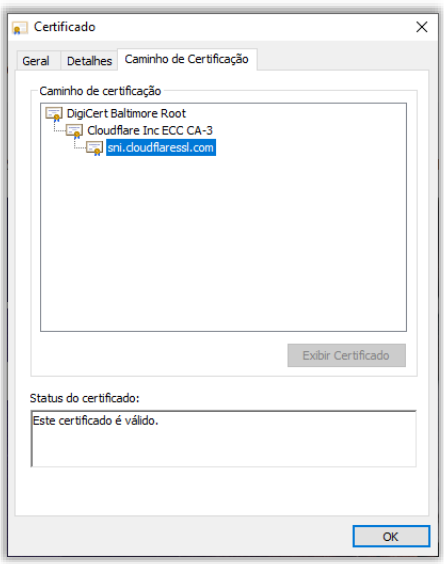
Em seguida, clique no cadeado à esquerda da barra de endereços e, logo depois, clique em Certificado. Um certificado digital será exibido em uma nova janela conforme podemos ver na imagem seguinte! Nunca se esqueçam de que o certificado digital é um documento/arquivo!



Vocês se lembram das informações contidas em um certificado digital? Uma informação muito importante anexada ao certificado era a assinatura da autoridade certificadora que o emitiu. Quando uma autoridade certificadora vai emitir um certificado digital, ela gera um hash de todas as informações do certificado e o assina com a sua chave privada. Dessa forma, todos que receberem o certificado digital poderão verificar sua autenticidade. *Como, professor?*







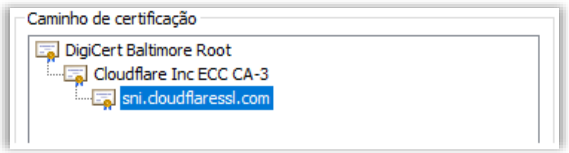
A entidade que recebeu o certificado terá em mãos o próprio certificado e seu hash anexado. Logo, ela poderá utilizar a chave pública da autoridade certificadora que emitiu o certificado para descriptografar

02854629116 - Willian de Santana Angola

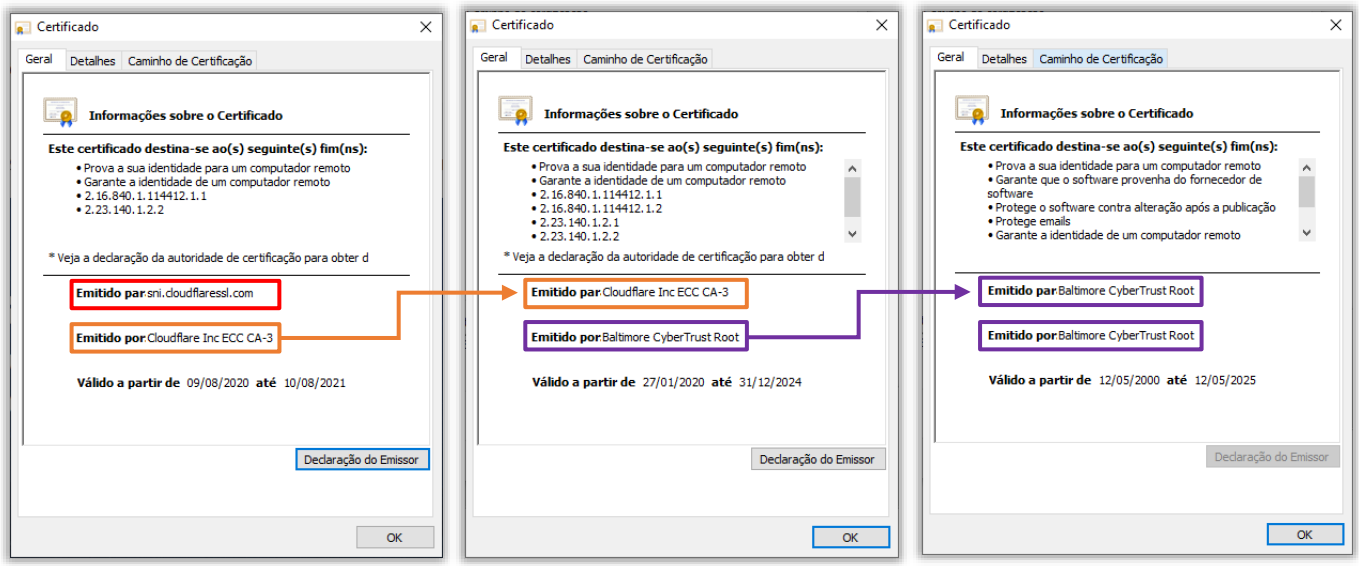
seu hash. Em seguida, ela poderá gerar um novo hash das informações do certificado digital e comparar com o hash anexado. Se os hashes forem idênticos, significa que o certificado não foi alterado e que é confiável.

Outro conceito importante apresentado nas imagens acima é o Caminho de Certificação. *Galera, vocês se lembram que uma infraestrutura de chave pública é uma estrutura hierarquizada?* Pois é, essa hierarquia cria um caminho de certificação quando uma autoridade certificadora raiz emite um certificado com sua assinatura digital para uma ou mais autoridades certificadoras intermediárias; e uma dessas emite um certificado com a sua assinatura digital para uma entidade qualquer!

Professor, e quem é que assina o certificado da autoridade certificadora raiz? Ela mesma! Nesse caso, dizemos que se trata de um certificado autoassinado.

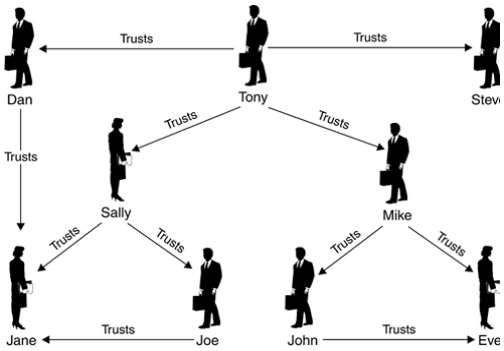


Acima nós temos o caminho de certificação do certificado da página do Estratégia Concursos. Observem a seguir que ele foi emitido para **sni.cloudflaressl.com** (que é o endereço do servidor onde a página está hospedada) e foi emitido/assinado por **Cloudflare Inc ECC CA-3** (AC intermediária). Já o certificado digital da **Cloudflare Inc ECC CA-3** foi emitido pela **Baltimore CyberTrust Root** (AC Raiz), que – no caso – emite/assina seu próprio certificado digital.



A infraestrutura de chave pública é uma abordagem interessante, mas ela é bastante hierárquica e centralizada. *E isso é um problema?* Pode ser! É possível ocorrer uma falha, vazamento ou corrupção na autoridade certificadora raiz, por exemplo. Logo, essa infraestrutura pode ser bastante vulnerável – um problema grave pode colocar em risco toda a infraestrutura. Dito isso, surgiu uma abordagem chamada Cadeia/Teia de Confiança (Web of Trust – WoT).

02854629116 - Willian de Santana Angola



O que seria isso, Diego? Trata-se de um modelo de confiança transitiva e descentralizada que busca disponibilizar criptografia para o público geral sem custos em contrapartida à abordagem de infraestrutura de chave pública. E como isso funciona, professor? A confiança vai sendo estabelecida através de uma rede de transitividade em que, se Tony confia em Mike e Mike confia em John, então Tony confia em John. Essa rede é construída por meio de uma relação pessoal indivíduos através da assinatura de chave pública de um usuário pelo outro e assim sucessivamente.

Essas etapas acabam por gerar um laço de confiança que se converte, então, em uma rede, teia ou cadeia de confiança. Dito isso, é importante fazer essa distinção: em uma infraestrutura de chave pública, todo certificado deve necessariamente ser assinado por uma autoridade certificadora. Já em uma cadeia/teia de certificados, qualquer entidade pode assinar e atestar a validade de outros certificados. Ela é – portanto – descentralizada e não hierárquica.

Tipos de Certificado

INCIDÊNCIA EM PROVA: MÉDIA

Os certificados digitais da Categoria A costumam ser usados para fins de identificação e autenticação. Você pode usá-los para assinar documentos ou validar transações eletrônicas. Já a Categoria S é direcionada a atividades sigilosas, como a proteção de arquivos confidenciais.

- **Certificado de Assinatura Digital (A):** reúne os certificados de assinatura digital, utilizados na confirmação de identidade na web, em e-mails, em Redes Privadas Virtuais (VPNs) e em documentos eletrônicos com verificação da integridade das informações.

- **Certificado de Sigilo (S):** reúne os certificados de sigilo, que são utilizados na codificação de documentos, de bases de dados relacionais, de mensagens e de outras informações eletrônicas sigilosas.

TIPO	GERAÇÃO DO PAR DE CHAVES	TAMANHO DA CHAVE (BITS)	ARMAZENAMENTO	VALIDADE MÁXIMA (ANOS)
CERTIFICADO A1/S1	Por software	Mínimo RSA 2048	Disco Rígido (HD) e Pendrive	1
CERTIFICADO A2/S2	Por software	Mínimo RSA 2048	Smartcard (com chip) ou Token USB	2
CERTIFICADO A3/S3	Por hardware	Mínimo RSA 2048	Smartcard (com chip) ou Token USB	5
CERTIFICADO A4/S4	Por hardware	Mínimo RSA 2048	Módulo de Segurança Criptográfica (HSM)	6

02854629116 - Willian de Santana Angola

QUESTÕES COMENTADAS – CEBRASPE

1. **(CEBRASPE / Prefeitura de Cachoeiro de Itapemirim-ES – 2024) O procedimento de associar a autenticação de dois fatores (2FA) ao uso de senha contribui muito pouco para o ganho de segurança da informação.**

Comentários:

A autenticação de dois fatores (2FA) adiciona uma camada extra de segurança ao exigir um segundo fator além da senha, como um código enviado ao celular. Isso dificulta acessos não autorizados, mesmo que a senha seja comprometida.

Gabarito: Errado

2. **(CEBRASPE / MPE-TO – 2024) O controle de acesso físico é um procedimento de segurança utilizado para garantir a segurança de informação de uma empresa.**

Comentários:

O controle de acesso físico é uma medida de segurança essencial para proteger informações, restringindo o acesso a áreas críticas, como data centers e salas de servidores. Isso evita acessos não autorizados que possam comprometer a integridade e confidencialidade dos dados.

Gabarito: Correto

3. **(CEBRASPE / MPE-TO – 2024) Ainda que muito eficiente, o uso de criptografia é insuficiente para garantir a segurança das informações em determinado computador.**

Comentários:

A criptografia protege a confidencialidade dos dados, mas, sozinha, não garante segurança total. Outros controles, como firewall, antivírus, autenticação forte e backup, são necessários para proteger contra ameaças como malware, acesso não autorizado e falhas do sistema.

Gabarito: Correto

4. **(CEBRASPE / MPE-TO – 2024) A assinatura digital é um dos recursos mais eficientes para garantir o sigilo de uma informação.**

Comentários:

A assinatura digital garante autenticidade, integridade e não repúdio, mas não assegura sigilo. Para garantir sigilo, é necessário o uso de criptografia, que protege os dados contra acesso não autorizado.

Gabarito: Errado

5. **(CEBRASPE / ITAIPU BINACIONAL – 2024) Tendo em vista que o uso diário de computadores para realizar atividades profissionais, de lazer ou estudos requer uma atenção especial por parte dos usuários, a fim de assegurar a proteção adequada de seus dados e arquivos, assinale a opção correta com referência às práticas fundamentais para garantir a segurança da informação.**

02854629116 - Willian de Santana Angola

a) Vírus de computador só tem capacidade de contaminar computadores que estiverem conectados em rede ou na Internet.

b) Manter softwares de antivírus atualizados impede o acesso não autorizado ao computador.

c) Mesclar letras, números e caracteres especiais na definição de senhas é uma boa prática para torná-las mais seguras.

d) O acesso a serviços on-line em computadores de uso compartilhado, como em faculdades ou lan houses, não representa risco se for realizado o logout nos serviços antes de desligar o computador.

e) Abrir arquivos ou clicar em links recebidos por e-mails enviados por remetentes conhecidos não representa risco de segurança.

Comentários:

(a) Errado. Vírus podem infectar computadores de diversas formas, incluindo dispositivos USB, e-mails, downloads e arquivos infectados, não sendo necessária conexão com a Internet ou rede;

(b) Errado. Antivírus atualizado protege contra malwares, mas não impede acessos não autorizados, pois essa função é desempenhada por firewalls e autenticação forte;

(c) Correto. Criar senhas fortes, mesclando letras, números e caracteres especiais, reduz a vulnerabilidade contra ataques de força bruta e tentativas de adivinhação;

(d) Errado. Mesmo após o logout, keyloggers e outros malwares podem capturar credenciais em computadores compartilhados. O ideal é usar modos anônimos e autenticação multifator;

(e) Errado. E-mails de phishing podem ser enviados por remetentes conhecidos se suas contas forem comprometidas. É essencial verificar links e anexos antes de abrir.

Gabarito: Letra C

6. (CEBRASPE / Prefeitura de São Cristóvão-SE – 2023) A respeito de segurança da informação, assinale a opção correta.

a) O mero recebimento de um link com malware é suficiente para que o dispositivo do usuário seja contaminado, mesmo que ele não clique no link.

b) A instalação e a configuração de aplicativos de segurança bastam para garantir a proteção de dados e informações armazenados em um computador.

c) Entre os procedimentos de segurança da informação, recomenda-se não abrir anexos de emails recebidos de usuário desconhecido.

d) A instalação de firewalls no computador apenas garante um melhor desempenho da máquina, sem colaborar para a segurança da informação.

Comentários:

02854629116 - Willian de Santana Angola

(a) Errado. O mero recebimento de um link com malware não infecta o dispositivo. A contaminação ocorre caso o usuário clique no link e execute um código malicioso;

(b) Errado. Apenas instalar e configurar aplicativos de segurança não é suficiente. Boas práticas, como atualizações regulares, autenticação forte e conscientização do usuário, são essenciais para proteção completa;

(c) Correto. Não abrir anexos de e-mails desconhecidos é uma recomendação de segurança para evitar phishing, malwares e ataques de engenharia social;

(d) Errado. Firewalls não servem para melhorar o desempenho, mas sim para controlar o tráfego de rede, protegendo contra acessos não autorizados e ameaças.

Gabarito: Letra C

7. (CEBRASPE / AGER-MT - 2023) A ICP-Brasil foi criada para viabilizar a emissão de certificados digitais no país, para transações que precisam de validade e segurança dos dados. Conforme o ITI, e considerando o uso de um certificado digital ICP-Brasil, é correto afirmar que a assinatura digital é:

a) A gerada a partir do uso do certificado digital ICP-Brasil e possui pleno valor jurídico garantido pela legislação brasileira.

b) importada no computador via a cadeia de certificação nível a3 e possui pleno valor jurídico garantido pela legislação brasileira.

c) gerada a partir do uso do certificado digital ICP-Brasil e seu valor jurídico depende da autoridade pública do município que é apresentado.

d) gerada por um navegador, que também autentica automaticamente o certificado emissor, e está restrita ao governo federal pelas regras do judiciário.

e) gerada a partir do uso do certificado digital ICP-Brasil e, uma vez assinado um documento, sua alteração é possível em qualquer situação nos sistemas de governo.

Comentários:

(a) Correto. A assinatura digital gerada com um certificado digital ICP-Brasil possui pleno valor jurídico, conforme a legislação brasileira, garantindo autenticidade, integridade e não repúdio;

(b) Errado. O valor jurídico da assinatura digital não depende do tipo de certificado (A1, A3, etc.), mas sim da ICP-Brasil, que garante sua validade legal;

(c) Errado. O valor jurídico não depende da autoridade pública municipal, mas sim da regulamentação da ICP-Brasil em nível nacional;

(d) Errado. A assinatura digital não é restrita ao governo federal e pode ser utilizada por empresas e cidadãos em diversas aplicações privadas e públicas;

(e) Errado. Após assinar um documento digitalmente, qualquer alteração invalida a assinatura, garantindo a integridade do conteúdo assinado.

02854629116 - Willian de Santana Angola

Gabarito: Letra A

8. (CEBRASPE / TRT8 - 2022) Em uma VPN, a confidencialidade dos dados garante que:

a) o conteúdo da mensagem não foi alterado durante a transmissão entre o emissor e o receptor.

b) o conteúdo da mensagem foi armazenado fisicamente em ambiente seguro.

c) a mensagem foi enviada por uma fonte autêntica e será entregue a um destino autêntico.

d) o emissor não poderá repudiar o envio da mensagem, ou seja, dizer que não enviou a referida mensagem.

e) a mensagem não poderá ser interpretada por origens não autorizadas.

Comentários:

(a) Errado, isso seria a integridade; (b) Errado, isso não tem nenhuma relação com confidencialidade; (c) Errado, isso seria autenticidade; (d) Errado, isso seria irretratabilidade ou não-repúdio; (e) Correto, essa definição representa perfeitamente a confidencialidade dos dados.

Gabarito: Letra E

9. (CEBRASPE / TRT8 - 2022) Em relação à criptografia assimétrica é correto afirmar que:

a) a criptografia de chave pública pode ser menos segura, em relação à criptoanálise, do que a criptografia simétrica.

b) a criptografia de chave pública é uma técnica de uso geral que tornou a criptografia simétrica obsoleta.

c) a distribuição de chave pública é sempre mais trivial e fácil quando comparada com o mecanismo de troca de mensagens para distribuição de chave para a criptografia simétrica.

d) envolve a utilização de duas chaves privadas para realizar a criptoanálise.

e) utiliza os algoritmos simétricos Data Encryption Standard (DES) e o Triple DES (DES triplo).

Comentários:

(a) Correto, não existe uma regra de qual tipo de criptografia (simétrica ou assimétrica) é mais segura, logo a criptografia assimétrica pode ser menos segura; (b) Errado, a criptografia simétrica ainda é amplamente utilizada; (c) Errado, não é sempre mais trivial e fácil; (d) Errado, utiliza uma chave pública e uma chave privada; (e) Errado, esses são algoritmos de criptografia simétrica.

Gabarito: Letra A

10. (CEBRASPE / DPDF - 2022) O algoritmo de hash é capaz de verificar e validar a integridade de um arquivo.

Comentários:

02854629116 - Willian de Santana Angola

A integridade é a capacidade de garantir que a informação manipulada está correta, fidedigna e que não foi corrompida. O algoritmo de hash é basicamente um algoritmo criptográfico que transforma uma entrada de dados em uma saída de dados de tamanho fixo. Dessa forma, se um único bit for alterado, teremos um resultado diferente. Logo, ele realmente é capaz de verificar e validar a integridade de um arquivo.

Gabarito: Correto

11.(CEBRASPE / DPDF - 2022) Se um arquivo deve ser transmitido entre dois computadores por meio da Internet, então, para agregar confidencialidade na transmissão, é correto aplicar um algoritmo de criptografia de chave simétrica.

Comentários:

A criptografia de chave simétrica é eficiente para garantir a confidencialidade na transmissão de dados, pois utiliza uma única chave secreta compartilhada entre as partes para cifrar e decifrar o conteúdo.

Gabarito: Correto

12.(CEBRASPE / DPDF - 2022) O uso de certificados digitais garante a autenticidade e a integridade de dados transmitidos entre duas redes de computadores, porém não oferece recursos de não repúdio na transmissão.

Comentários:

O certificado digital pode garantir a autenticidade e a integridade e, quando esses princípios são garantidos, a garantia do não-repúdio é automática. Relembrando que o não-repúdio é também chamado de irrefutabilidade ou irretratabilidade – ele trata da capacidade de garantir que o emissor da mensagem ou participante de um processo não negue posteriormente a sua autoria.

Gabarito: Errado

13.(CEBRASPE / SEFAZ-SE – 2022) Na disciplina de criptografia, a proteção das informações trafegadas está relacionada ao conceito de:

a) autenticação.
b) confidencialidade dos dados.
c) integridade dos dados.
d) controle de acesso.
e) irretratabilidade.

Comentários:

(a) Errado. Autenticação garante a identidade das partes envolvidas, mas não protege diretamente as informações trafegadas;

(b) Correto. Confidencialidade é o conceito que assegura que as informações trafegadas não sejam acessadas por pessoas não autorizadas, sendo garantida por técnicas como a criptografia;

(c) Errado. Integridade garante que os dados não foram alterados indevidamente, mas não trata do sigilo durante a transmissão;

02854629116 - Willian de Santana Angola

(d) Errado. Controle de acesso define quem pode acessar o quê, mas não se aplica diretamente à proteção dos dados em trânsito;

(e) Errado. Irretratabilidade (ou não repúdio) impede que o autor negue a autoria de uma ação, mas não protege o conteúdo trafegado.

Gabarito: Letra B

14.(CEBRASPE / SEFAZ-AL – 2021) O uso de senhas ou a adoção de identificação física, como biometrias, são formas de autenticação para fins de identificação única e exclusiva de usuários.

Comentários:

Perfeito! Senha (algo que você sabe) e Biometria (algo que você é) podem ser utilizados para fins de autenticação, isto é, identificação única e exclusiva de usuários.

Gabarito: Correto

15.(CEBRASPE / SEFAZ-AL – 2021) A criptografia assimétrica utiliza duas chaves, uma pública e outra privada, para cifrar e decifrar mensagens.

Comentários:

Perfeito! *Questão tão simples que vocês ficaram até com medo de marcar né?* Admitam! A criptografia assimétrica usa um par de chaves: uma pública (divulgada) para cifrar e uma privada (secreta) para decifrar, garantindo confidencialidade e autenticação.

Gabarito: Correto

16.(CEBRASPE / SEFAZ-AL – 2021) A autoridade certificadora é uma entidade responsável por validar a identidade de um usuário em uma infraestrutura de chaves públicas ICP.

Comentários:

Questão polêmica! A Autoridade Certificadora é a entidade responsável por emitir, distribuir, renovar, revogar e gerenciar certificados digitais. Já a Autoridade de Registro é a entidade responsável por receber, validar, encaminhar solicitações de emissão ou revogação de certificados digitais. Logo, discordo do gabarito da banca...

Gabarito: Correto

17.(CEBRASPE / SEFAZ-AL – 2021) Para se associar uma mensagem a seu remente, utiliza-se uma assinatura digital, a qual é um arquivo que contém os dados que determinam a identidade de usuários ou de máquinas (servidores).

Comentários:

Para associar uma mensagem a seu remetente, utiliza-se um certificado digital. Ele, sim, é um arquivo que contém dados que determinam a identidade de usuários ou de máquinas/servidores. No entanto, como houve um erro de grafia em "remente" em vez de "remetente", a questão foi anulada.

Gabarito: Anulada

02854629116 - Willian de Santana Angola

18.(CEBRASPE / DPE-RO – 2021) Considere que um documento assinado digitalmente com a chave privada do emissor e posteriormente criptografado com a chave pública do destinatário tenha sido recebido, visualizado e lido pelo destinatário. Nessa situação, a autoria desse documento ainda poderia ser questionada caso o suposto emissor alegasse:

a) a não validade da chave pública usada para a criptografia.
b) a indevida distribuição de sua chave pública.
c) a necessidade de que a assinatura fosse feita com sua chave pública.
d) o comprometimento de sua chave privada anteriormente à assinatura.
e) a inversão de ordem no processo de assinatura e criptografia.

Comentários:

(a) Errado. A validade da chave pública usada para criptografar não compromete a autoria, pois a assinatura digital foi feita com a chave privada do emissor;

(b) Errado. A chave pública é, por definição, amplamente distribuída; isso não compromete a autoria nem o processo de assinatura digital;

(c) Errado. Assinaturas digitais são feitas com a chave privada do emissor, não com a chave pública;

(d) Correto. Se a chave privada do emissor foi comprometida antes da assinatura, ele pode alegar que terceiros a utilizaram indevidamente, o que compromete a confiabilidade da autoria;

(e) Errado. A ordem (assinar antes de criptografar) é uma prática comum e não invalida a autenticidade, desde que as chaves estejam seguras.

Gabarito: Letra D

19.(CEBRASPE / TELEBRÁS - 2021) No Brasil, a certificação digital contempla quatro conjuntos de certificados, cada um com sua função: assinatura digital (A1, A2, A3 e A4), sigilo (S1, S2, S3 e S4), tempo (T) e mobilidade (Bird ID). No conjunto de certificados de assinatura digital, os modelos A4 e A3 são muito semelhantes, mas este se distingue daquele por ser específico para uso em nuvem e por ser armazenado em um hardware criptográfico chamado HSM.

Comentários:

O certificado A4 é o que tem armazenamento em nuvem, geralmente hospedado em um HSM, permitindo mobilidade e uso remoto. Já o A3 é emitido e armazenado fisicamente em token ou smartcard, não em nuvem.

Gabarito: Errado

20.(CEBRASPE / SERPRO – 2021) Para arquivos criptografados com algoritmos que utilizam chaves de até 256 bits, é viável realizar ataques de força bruta no espaço de chaves, com real possibilidade de sucesso em tempo aceitável.

Comentários:

É completamente inviável! Os recursos necessários para um ataque de força bruta aumentam exponencialmente com o aumento tamanho da chave, não linearmente. Atualmente, há um argumento

02854629116 - Willian de Santana Angola

físico (relacionado ao gasto de energia) de que uma chave simétrica de 128 bits é computacionalmente segura contra ataques de força bruta. Quebrar uma chave simétrica de 256 bits por força bruta requer 2^{128} vezes mais poder computacional do que uma chave de 128 bits. Um dos supercomputadores mais rápidos em 2019 tem uma velocidade de 100 Petaflops, que poderia teoricamente verificar 100 milhões de milhões (10^{14}) chaves por segundo (assumindo 1000 operações por verificação), mas ainda exigiria $3,67 \times 10^{55}$ anos para esgotar o espaço da chave de 256 bits.

Gabarito: Errado

21.(CEBRASPE / SERPRO – 2021) Dados sobre os quais tenha sido calculado um valor de hash criptográfico com determinado algoritmo têm garantia de sua integridade sempre que, em qualquer tempo, um novo cálculo de hash desses dados com emprego do mesmo algoritmo resultar idêntico ao valor inicialmente calculado.

Comentários:

Perfeito! Se eu aplico um algoritmo de hash criptográfico a um conjunto de dados, eu obtenho um hash (resumo da mensagem). Caso eu aplique, em qualquer tempo, o mesmo algoritmo de hash nesse mesmo conjunto de dado e obtenha o mesmo hash, está garantida a integridade dos dados.

Gabarito: Correto

22.(CEBRASPE / SERPRO – 2021) Os tokens de autenticação, que podem ser dispositivos físicos ou podem existir em software, geram códigos vinculados a determinado dispositivo, usuário ou conta, que podem ser usados uma vez como parte de um processo de autenticação em um intervalo de tempo.

Comentários:

Tokens de autenticação, físicos ou em software, geram códigos temporários e de uso único (OTP), que fortalecem a segurança ao serem usados como um segundo fator de autenticação.

Gabarito: Correto

23.(CEBRASPE / Polícia Federal – 2021) Se, quando do acesso ao sítio https://gov.br/pf/pt-br na versão mais recente do Google Chrome, for visualizado o ícone de um cadeado cinza ao lado da URL, o símbolo em questão estará sinalizando que esse ambiente refere-se à intranet da Polícia Federal.

Comentários:

O cadeado cinza ao lado da URL indica apenas que a página que se está tentando acessar possui um Certificado Digital SSL, logo a comunicação com o servidor que hospeda a página é segura e criptografada. Lembremos que HTTPS é o HTTP + SSL/TLS, logo qualquer sítio que tenha o símbolo de um cadeado cinza ao lado da URL estará sinalizando que essa comunicação com o sítio é segura e, não, que se refere à intranet. Viagem da questão...

Gabarito: Errado

24.(CEBRASPE / Ministério da Economia – 2020) Integridade é a característica que garante o acesso à informação somente para quem estiver autorizado.

02854629116 - Willian de Santana Angola

Comentários:

A característica que garante acesso à informação apenas por usuários autorizados é a confidencialidade. Integridade refere-se à proteção contra alterações não autorizadas nos dados.

Gabarito: Errado

25.(CEBRASPE / SEFAZ-AL – 2020) Identificação e autenticação são requisitos de segurança da informação que consistem em identificar usuários do sistema e verificar as suas identidades, como pré-requisito para permitir o acesso desses usuários ao sistema.

Comentários:

Identificação e autenticação realmente podem ser consideradas requisitos de segurança da informação! Identificação é simplesmente o processo de identificar unicamente um usuário em um sistema; autenticação é o processo que garante que uma entidade é realmente quem diz ser; Logo, identificação consiste em identificar usuários do sistema; autenticação consiste em verificar suas identidades; e ambas são pré-requisitos para permitir o acesso aos usuários ao sistema.

Gabarito: Correto

26.(CEBRASPE / Ministério da Economia - 2020) Esteganografia é uma técnica que consiste em ocultar uma mensagem dentro da outra, enquanto a criptografia é uma técnica que codifica o conteúdo da mensagem.

Comentários:

A esteganografia oculta a existência da mensagem (por exemplo, dentro de uma imagem), enquanto a criptografia transforma o conteúdo para torná-lo ilegível a terceiros não autorizados.

Gabarito: Correto

27.(CEBRASPE / SEFAZ-DF - 2020) A assinatura digital foi desenvolvida especialmente com o objetivo de prover confidencialidade. Para criá-la, basta que o emissor gere um hash da mensagem enviada e cifre esse código hash com sua chave privada.

Comentários:

Opa... a assinatura digital foi desenvolvida especialmente com o objetivo de prover autenticidade, integridade e não-repúdio – confidencialidade, não! O restante da questão está perfeito!

Gabarito: Errado

28.(CEBRASPE / TJ-PA - 2020) Na tecnologia da informação, o uso de recursos criptográficos é cada vez mais essencial para a manutenção da segurança da informação, que, conforme a forma de criptografia, pode fornecer:

I integridade.
II autenticidade.
III confidencialidade.

02854629116 - Willian de Santana Angola

Considerando o que os algoritmos de chaves públicas podem prover, assinale a opção correta.

a) Apenas o item I está certo.
b) Apenas o item II está certo.
c) Apenas os itens I e III estão certos.
d) Apenas os itens II e III estão certos.
e) Todos os itens estão certos.

Comentários:

A utilização simples de algoritmos de chave pública não garante a integridade dos dados. Não há nada que impeça que um terceiro intercepte uma mensagem criptografada por meio de um algoritmo de chave pública e a modifique, ferindo a sua integridade. Para garantir a integridade dos dados, utilizam-se funções de hash. De fato, a autenticidade é garantida por algoritmos de chave pública ao criptografar uma mensagem com a chave privada do emissor; e a confidencialidade é garantida por algoritmos de chave pública ao criptografar uma mensagem com a chave pública do receptor. Agora o detalhe: a questão afirma que algoritmos de chaves públicas "podem prover...". Ora, dependendo da forma de utilização, pode sim! Caberia recurso...

Gabarito: Letra D

29.(CEBRASPE / SEFAZ/RS – 2019) Para o estabelecimento de padrões de segurança, um dos princípios críticos é a necessidade de se verificar a legitimidade de uma comunicação, de uma transação ou de um acesso a algum serviço. Esse princípio refere-se à:

a) confidencialidade.
- b) autenticidade.
c) integridade.
d) conformidade.
e) disponibilidade.

Comentários:

(a) Errado. Confidencialidade refere-se à proteção da informação contra acessos não autorizados, não à verificação de legitimidade;

(b) Correto. Autenticidade garante que a comunicação, transação ou acesso seja realizado por uma entidade legítima, validando a identidade do remetente ou solicitante;

(c) Errado. Integridade assegura que a informação não foi alterada indevidamente, mas não trata da verificação da legitimidade;

(d) Errado. Conformidade refere-se ao atendimento a normas e políticas, não à legitimidade de acessos ou transações;

(e) Errado. Disponibilidade trata do acesso contínuo e oportuno às informações e serviços, não da verificação de legitimidade.

Gabarito: Letra B

02854629116 - Willian de Santana Angola

30.(CEBRASPE / TJ-AM – 2019) Um certificado digital validado por uma autoridade certificadora permite associar uma mensagem ao seu remetente, garantindo-se, assim, a autenticidade da comunicação.

Comentários:

Um certificado digital validado por uma autoridade certificadora permite associar com segurança a identidade do remetente à mensagem, garantindo a autenticidade da comunicação.

Gabarito: Correto

02854629116 - Willian de Santana Angola

LISTA DE QUESTÕES – CEBRASPE

1. **(CEBRASPE / Prefeitura de Cachoeiro de Itapemirim-ES – 2024) O procedimento de associar a autenticação de dois fatores (2FA) ao uso de senha contribui muito pouco para o ganho de segurança da informação.**

2. **(CEBRASPE / MPE-TO – 2024) O controle de acesso físico é um procedimento de segurança utilizado para garantir a segurança de informação de uma empresa.**

3. **(CEBRASPE / MPE-TO – 2024) Ainda que muito eficiente, o uso de criptografia é insuficiente para garantir a segurança das informações em determinado computador.**

4. **(CEBRASPE / MPE-TO – 2024) A assinatura digital é um dos recursos mais eficientes para garantir o sigilo de uma informação.**

5. **(CEBRASPE / ITAIPU BINACIONAL – 2024) Tendo em vista que o uso diário de computadores para realizar atividades profissionais, de lazer ou estudos requer uma atenção especial por parte dos usuários, a fim de assegurar a proteção adequada de seus dados e arquivos, assinale a opção correta com referência às práticas fundamentais para garantir a segurança da informação.**

   a) Vírus de computador só tem capacidade de contaminar computadores que estiverem conectados em rede ou na Internet.

   b) Manter softwares de antivírus atualizados impede o acesso não autorizado ao computador.

   c) Mesclar letras, números e caracteres especiais na definição de senhas é uma boa prática para torná-las mais seguras.

   d) O acesso a serviços on-line em computadores de uso compartilhado, como em faculdades ou lan houses, não representa risco se for realizado o logout nos serviços antes de desligar o computador.

   e) Abrir arquivos ou clicar em links recebidos por e-mails enviados por remetentes conhecidos

6. **(CEBRASPE / Prefeitura de São Cristóvão-SE – 2023) A respeito de segurança da informação, assinale a opção correta.**

   a) O mero recebimento de um link com malware é suficiente para que o dispositivo do usuário seja contaminado, mesmo que ele não clique no link.

   b) A instalação e a configuração de aplicativos de segurança bastam para garantir a proteção de dados e informações armazenados em um computador.

   c) Entre os procedimentos de segurança da informação, recomenda-se não abrir anexos de emails recebidos de usuário desconhecido.

   d) A instalação de firewalls no computador apenas garante um melhor desempenho da máquina, sem colaborar para a segurança da informação.

7. **(CEBRASPE / AGER-MT - 2023) A ICP-Brasil foi criada para viabilizar a emissão de certificados digitais no país, para transações que precisam de validade e segurança dos dados. Conforme o**

02854629116 - Willian de Santana Angola

ITI, e considerando o uso de um certificado digital ICP-Brasil, é correto afirmar que a assinatura digital é:

a) A gerada a partir do uso do certificado digital ICP-Brasil e possui pleno valor jurídico garantido pela legislação brasileira.

b) importada no computador via a cadeia de certificação nível a3 e possui pleno valor jurídico garantido pela legislação brasileira.

c) gerada a partir do uso do certificado digital ICP-Brasil e seu valor jurídico depende da autoridade pública do município que é apresentado.

d) gerada por um navegador, que também autentica automaticamente o certificado emissor, e está restrita ao governo federal pelas regras do judiciário.

e) gerada a partir do uso do certificado digital ICP-Brasil e, uma vez assinado um documento, sua alteração é possível em qualquer situação nos sistemas de governo.

8. (CEBRASPE / TRT8 - 2022) Em uma VPN, a confidencialidade dos dados garante que:

a) o conteúdo da mensagem não foi alterado durante a transmissão entre o emissor e o receptor.

b) o conteúdo da mensagem foi armazenado fisicamente em ambiente seguro.

c) a mensagem foi enviada por uma fonte autêntica e será entregue a um destino autêntico.

d) o emissor não poderá repudiar o envio da mensagem, ou seja, dizer que não enviou a referida mensagem.

e) a mensagem não poderá ser interpretada por origens não autorizadas.

9. (CEBRASPE / TRT8 - 2022) Em relação à criptografia assimétrica é correto afirmar que:

a) a criptografia de chave pública pode ser menos segura, em relação à criptoanálise, do que a criptografia simétrica.

b) a criptografia de chave pública é uma técnica de uso geral que tornou a criptografia simétrica obsoleta.

c) a distribuição de chave pública é sempre mais trivial e fácil quando comparada com o mecanismo de troca de mensagens para distribuição de chave para a criptografia simétrica.

d) envolve a utilização de duas chaves privadas para realizar a criptoanálise.

e) utiliza os algoritmos simétricos Data Encryption Standard (DES) e o Triple DES (DES triplo).

10. (CEBRASPE / DPDF - 2022) O algoritmo de hash é capaz de verificar e validar a integridade de um arquivo.

11. (CEBRASPE / DPDF - 2022) Se um arquivo deve ser transmitido entre dois computadores por meio da Internet, então, para agregar confidencialidade na transmissão, é correto aplicar um algoritmo de criptografia de chave simétrica.

02854629116 - Willian de Santana Angola

12.(CEBRASPE / DPDF - 2022) O uso de certificados digitais garante a autenticidade e a integridade de dados transmitidos entre duas redes de computadores, porém não oferece recursos de não repúdio na transmissão.

13.(CEBRASPE / SEFAZ-SE – 2022) Na disciplina de criptografia, a proteção das informações trafegadas está relacionada ao conceito de:

a) autenticação.
b) confidencialidade dos dados.
c) integridade dos dados.
d) controle de acesso.
e) irretratabilidade.

14.(CEBRASPE / SEFAZ-AL – 2021) O uso de senhas ou a adoção de identificação física, como biometrias, são formas de autenticação para fins de identificação única e exclusiva de usuários.

15.(CEBRASPE / SEFAZ-AL – 2021) A criptografia assimétrica utiliza duas chaves, uma pública e outra privada, para cifrar e decifrar mensagens.

16.(CEBRASPE / SEFAZ-AL – 2021) A autoridade certificadora é uma entidade responsável por validar a identidade de um usuário em uma infraestrutura de chaves públicas ICP.

17.(CEBRASPE / SEFAZ-AL – 2021) Para se associar uma mensagem a seu remetente, utiliza-se uma assinatura digital, a qual é um arquivo que contém os dados que determinam a identidade de usuários ou de máquinas (servidores).

18.(CEBRASPE / DPE-RO – 2021) Considere que um documento assinado digitalmente com a chave privada do emissor e posteriormente criptografado com a chave pública do destinatário tenha sido recebido, visualizado e lido pelo destinatário. Nessa situação, a autoria desse documento ainda poderia ser questionada caso o suposto emissor alegasse:

a) a não validade da chave pública usada para a criptografia.
b) a indevida distribuição de sua chave pública.
c) a necessidade de que a assinatura fosse feita com sua chave pública.
d) o comprometimento de sua chave privada anteriormente à assinatura.
e) a inversão de ordem no processo de assinatura e criptografia.

19.(CEBRASPE / TELEBRÁS - 2021) No Brasil, a certificação digital contempla quatro conjuntos de certificados, cada um com sua função: assinatura digital (A1, A2, A3 e A4), sigilo (S1, S2, S3 e S4), tempo (T) e mobilidade (Bird ID). No conjunto de certificados de assinatura digital, os modelos A4 e A3 são muito semelhantes, mas este se distingue daquele por ser específico para uso em nuvem e por ser armazenado em um hardware criptográfico chamado HSM.

20.(CEBRASPE / SERPRO – 2021) Para arquivos criptografados com algoritmos que utilizam chaves de até 256 bits, é viável realizar ataques de força bruta no espaço de chaves, com real possibilidade de sucesso em tempo aceitável.

21.(CEBRASPE / SERPRO – 2021) Dados sobre os quais tenha sido calculado um valor de hash criptográfico com determinado algoritmo têm garantia de sua integridade sempre que, em qualquer tempo, um novo cálculo de hash desses dados com emprego do mesmo algoritmo resultar idêntico ao valor inicialmente calculado.

02854629116 - Willian de Santana Angola

22.(CEBRASPE / SERPRO – 2021) Os tokens de autenticação, que podem ser dispositivos físicos ou podem existir em software, geram códigos vinculados a determinado dispositivo, usuário ou conta, que podem ser usados uma vez como parte de um processo de autenticação em um intervalo de tempo.

23.(CEBRASPE / Polícia Federal – 2021) Se, quando do acesso ao sítio https://gov.br/pf/pt-br na versão mais recente do Google Chrome, for visualizado o ícone de um cadeado cinza ao lado da URL, o símbolo em questão estará sinalizando que esse ambiente refere-se à intranet da Polícia Federal.

24. (CEBRASPE / Ministério da Economia – 2020) Integridade é a característica que garante o acesso à informação somente para quem estiver autorizado.

25. (CEBRASPE / SEFAZ-AL – 2020) Identificação e autenticação são requisitos de segurança da informação que consistem em identificar usuários do sistema e verificar as suas identidades, como pré-requisito para permitir o acesso desses usuários ao sistema.

26. (CEBRASPE / Ministério da Economia - 2020) Esteganografia é uma técnica que consiste em ocultar uma mensagem dentro da outra, enquanto a criptografia é uma técnica que codifica o conteúdo da mensagem.

27. (CEBRASPE / SEFAZ-DF - 2020) A assinatura digital foi desenvolvida especialmente com o objetivo de prover confidencialidade. Para criá-la, basta que o emissor gere um hash da mensagem enviada e cifre esse código hash com sua chave privada.

28. (CEBRASPE / TJ-PA - 2020) Na tecnologia da informação, o uso de recursos criptográficos é cada vez mais essencial para a manutenção da segurança da informação, que, conforme a forma de criptografia, pode fornecer:

I integridade.
II autenticidade.
III confidencialidade.

Considerando o que os algoritmos de chaves públicas podem prover, assinale a opção correta.

a) Apenas o item I está certo.
b) Apenas o item II está certo.
c) Apenas os itens I e III estão certos.
d) Apenas os itens II e III estão certos.
e) Todos os itens estão certos.

29. (CEBRASPE / SEFAZ/RS – 2019) Para o estabelecimento de padrões de segurança, um dos princípios críticos é a necessidade de se verificar a legitimidade de uma comunicação, de uma transação ou de um acesso a algum serviço. Esse princípio refere-se à:

a) confidencialidade.
b) autenticidade.
c) integridade.
d) conformidade.
e) disponibilidade.

02854629116 - Willian de Santana Angola

30. (CEBRASPE / TJ-AM – 2019) Um certificado digital validado por uma autoridade certificadora permite associar uma mensagem ao seu remetente, garantindo-se, assim, a autenticidade da comunicação.

GABARITO – CEBRASPE

1.	ERRADO	**11.**	CORRETO	**21.**	CORRETO
2.	CORRETO	**12.**	ERRADO	**22.**	CORRETO
3.	CORRETO	**13.**	LETRA B	**23.**	ERRADO
4.	ERRADO	**14.**	CORRETO	**24.**	ERRADO
5.	LETRA C	**15.**	CORRETO	**25.**	CORRETO
6.	LETRA C	**16.**	CORRETO	**26.**	CORRETO
7.	LETRA A	**17.**	ANULADA	**27.**	ERRADO
8.	LETRA E	**18.**	LETRA D	**28.**	LETRA D
9.	LETRA A	**19.**	ERRADO	**29.**	LETRA B
10.	CORRETO	**20.**	ERRADO	**30.**	CORRETO

02854629116 - Willian de Santana Angola

ESSA LEI TODO MUNDO CONHECE:
PIRATARIA É CRIME.

Mas é sempre bom revisar o porquê e como você pode ser prejudicado com essa prática.

1. 

Professor investe seu tempo para elaborar os cursos e o site os coloca à venda.

2. 

Pirata divulga ilicitamente (grupos de rateio), utilizando-se do anonimato, nomes falsos ou laranjas (geralmente o pirata se anuncia como formador de "grupos solidários" de rateio que não visam lucro).

3. 

Pirata cria alunos fake praticando falsidade ideológica, comprando cursos do site em nome de pessoas aleatórias (usando nome, CPF, endereço e telefone de terceiros sem autorização).

4. 

Pirata compra, muitas vezes, clonando cartões de crédito (por vezes o sistema anti-fraude não consegue identificar o golpe a tempo).

5. 

Pirata fere os Termos de Uso, adultera as aulas e retira a identificação dos arquivos PDF (justamente porque a atividade é ilegal e ele não quer que seus fakes sejam identificados).

6. 

Pirata revende as aulas protegidas por direitos autorais, praticando concorrência desleal e em flagrante desrespeito à Lei de Direitos Autorais (Lei 9.610/98).

7. 

Concurseiro(a) desinformado participa de rateio, achando que nada disso está acontecendo e esperando se tornar servidor público para exigir o cumprimento das leis.

8. 

O professor que elaborou o curso não ganha nada, o site não recebe nada, e a pessoa que praticou todos os ilícitos anteriores (pirata) fica com o lucro.



Deixando de lado esse mar de sujeira, aproveitamos para agradecer a todos que adquirem os cursos honestamente e permitem que o site continue existindo.